

4. 变更请求

在实施采购的过程中,可能发现原来的项目计划有遗漏,或者市场条件发生了变化。此时可以提出对项目管理计划、子计划和其他组成部分的变更请求,并提交实施整体变更控制过程审查与处理。

5. 项目管理计划更新

在实施采购的过程中,如果有变更,那可能要调整项目管理计划。项目管理计划中可能需要更新的内容包括但不限于:

- (1) 成本基准;
- (2) 范围基准;
- (3) 进度基准;
- (4) 沟通管理计划;
- (5) 采购管理计划。

6. 项目文件更新

可能需要更新的项目文件包括需求文件、需求跟踪文件、风险登记册、干系人登记册。

14.4 招投标

本节的内容依据《中华人民共和国招标投标法》相关条款的规定、参考行业内的常规做法编制而成。

招投标是实施采购的一种常见形式。

14.4.1 招标人及其权利和义务

招标人是依照《中华人民共和国招标投标法》规定提出招标项目、进行招标的法人或者其他组织。

1. 招标人的权利

招标人有如下权力。

(1) 招标人有权自行选择招标代理机构,委托其办理招标事宜。招标人具有编制招标文件和组织评标能力的,可以自行办理招标事宜。

(2) 自主选定招标代理机构并核验其资质条件。

(3) 招标人可以根据招标项目本身的要求,在招标公告或者投标邀请书中,要求潜在投标人提供有关资质证明文件和业绩情况,并对潜在投标人进行资格预审;国家对投标人资格条件有规定的,应按照其规定。

(4) 在要求提交投标文件截止时间至少 15 日前,招标人可以以书面形式对已发出的招标文件进行必要的澄清或者修改。该澄清或者修改内容是招标文件的组成部分。

(5) 招标人有权也应当对在招标文件要求提交的截止时间后送达的投标文件拒收。

(6) 开标由招标人主持。

(7) 招标人根据评标委员会提出的书面评估报告和推荐的中标候选人确定中标人。招标人也可以授权评标委员会直接确定中标人。

2. 招标人的义务

招标人有如下义务。

(1) 招标人委托招标代理机构时，应当向其提供招标所需要的有关资料并支付委托费。

(2) 招标人不得以不合理条件限制或者排斥潜在投标人，不得对潜在投标人实行歧视待遇。

(3) 招标文件不得要求或者标明特定的生产供应者，以及含有倾向或者排斥潜在投标人的其他内容。

(4) 招标人不得向他人透露已获取招标文件的潜在投标人的名称、数量，以及可能影响公平竞争的有关招标投标的其他情况。招标人设有标底的，标底必须保密。

(5) 招标人应当确定投标人编制投标文件所需要的合理时间。但是，依法必须进行招标的项目，自招标文件开始发出之日起至提交投标文件截止之日止，最短不得少于20日。

(6) 招标人在招标文件要求提交投标文件的截止时间前收到的所有投标文件，开标时都应当众予以拆封、宣读。

(7) 招标人应当采取必要的措施，保证评标在严格保密的情况下进行。

(8) 中标人确定后，招标人应当向中标人发出中标通知书，并同时将在中标结果通知所有未中标的投标人。

(9) 招标人和中标人应当自中标通知书发出之日起30日内，按照招标文件和中标人的投标文件订立书面合同。

14.4.2 招标代理机构

1. 招标代理机构的法律地位

招标代理机构是独立于政府和企业之外的，为市场主体提供招标服务的专业机构，属于中介服务组织。它的招标代理资格需经国家招标投标主管机关的严格认证。

2. 招标代理机构的权利和义务

在招标投标活动中，招标代理机构的权利和承担的义务分别如下。

1) 招标代理机构的权利

- (1) 组织和参与招标活动。
- (2) 依据招标文件规定，审查投标人的资质。
- (3) 按规定标准收取招标代理费。

2) 招标代理机构的义务

- (1) 维护招标人和投标人的合法利益。
- (2) 组织编制、解释招标文件。

(3) 接受国家招标投标管理机构和有关行业组织的指导、监督。

14.4.3 招标方式

招标分为公开招标和邀请招标。

(1) 公开招标：指招标人以招标公告的方式邀请不特定的法人或者其他组织投标。

(2) 邀请招标：指招标人以投标邀请书的方式邀请特定的法人或者其他组织投标。

14.4.4 招投标程序

依据《中华人民共和国招标投标法》，招投标程序如下。

(1) 招标人采用公开招标方式的，应当发布招标公告；招标人采用邀请招标方式的，应当向三个以上具备承担招标项目能力的、资信良好的特定的法人或者其他组织发出投标邀请书。

(2) 招标人根据招标项目的具体情况，可以组织潜在投标人踏勘项目现场。

(3) 投标人投标。

(4) 开标。

(5) 评标。

(6) 确定中标人。

(7) 订立合同。

14.4.5 投标

(1) 投标人应当按照招标文件的要求编制投标文件。投标文件应当对招标文件提出的实质性要求和条件做出实质性响应。

(2) 投标人应当在招标文件要求提交投标文件的截止时间前，将投标文件送达投标地点。

(3) 投标人在招标文件要求提交投标文件的截止时间前，可以补充、修改或者撤回已提交的投标文件，并书面通知招标人。

(4) 投标人根据招标文件载明的项目实际情况，拟在中标后将中标项目的部分非主体、非关键性工作进行分包的，应当在投标文件中载明。

两个以上法人或者其他组织可以组成一个联合体，以一个投标人的身份共同投标。

14.4.6 开标、评标和中标

1. 开标

开标应当在招标文件确定的提交投标文件截止时间的同一时间公开进行；开标地点

应当为招标文件中预先确定的地点。开标由招标人主持，邀请所有投标人参加。开标时，由投标人或者其推选的代表检查投标文件的密封情况，也可以由招标人委托的公证机构检查并公证。经确认无误后，由工作人员当众拆封，宣读投标人名称、投标价格和投标文件的其他主要内容。在招标文件要求提交投标文件的截止时间前收到的所有投标文件，开标时都应当当众予以拆封、宣读。开标过程应当记录，并存档备查。

2. 评标

评标由招标人依法组建的评标委员会负责。依法必须进行招标的项目，其评标委员会由招标人的代表和有关技术、经济等方面的专家组成，评标委员会组成方式与专家资质将依据《中华人民共和国招标投标法》有关条款来确定。

评标委员会可以要求投标人对投标文件中含义不明确的内容做必要的澄清或者说明，但是澄清或者说明不得超出投标文件的范围或者改变投标文件的实质性内容。

评标委员会应当按照招标文件确定的评标标准和方法，对投标文件进行评审和比较；评标委员会完成评标后，应当向招标人提出书面评标报告，并推荐合格的中标候选人。招标人根据评标委员会提出的书面评标报告和推荐的中标候选人确定中标人。招标人也可以授权评标委员会直接确定中标人。

中标人的投标应当符合下列条件之一。

(1) 能够最大限度地满足招标文件中规定的各项综合评价标准。

(2) 能够满足招标文件的实质性要求，并且经评审的投标价格最低。但是，投标价格低于成本的除外。

3. 中标

中标人确定后，招标人应当向中标人发出中标通知书，并同时将中标结果通知所有未中标的投标人。

招标人和中标人应当自中标通知书发出之日起 30 日内，按照招标文件和中标人的投标文件订立书面合同。招标人和中标人不得再行订立背离合同实质性内容的其他协议。

中标人应当按照合同约定履行义务，完成中标项目。

14.4.7 供方选择

前面的询价计划编制过程为供方选择过程提供了评估标准。除了使用采购成本或价格外，这个过程中还会使用综合评价标准。

价格对于现货供应、同质的物品可能是主要的决定因素。不过如果卖方不能及时供货的话，最低的价格并不能保证最低的成本。对于项目中产品子系统的采购（即外包、发包），或对服务的采购来说，针对供应商的技术方案和管理方案等，也可以考虑综合评价标准。表 14-2 是某项目对供应商的评价表。假定每个评价项满分为 10 分。表 14-2 中，针对“对需求的理解”的评价项，3 个评定人的打分分别为 6、6、9，平均为 7 分，最后 7 乘以权重比例 0.15，得到“对需求的理解”的单项综合分为 1.05，依此类推，每个供

应商有一加权后的技术管理总分，加上价格方面的分数之后（原则是价格低应获得价格方面的高分），得到供应商的总分。对所有供应商的总分排序，以确定谈判顺序，然后选择一个卖方，并要求签订标准合同。

对于那些关键性采购应采用多渠道以规避风险（如送货不及时、不合质量要求等风险）。但更多渠道采购可能导致更高的采购成本。

表 14-2 某项目采购供应商的评价表

供应商名称: _____ 年 月 日					
权重等	权重比例	第1评定人	第2评定人	第3评定人	单项综合
评价项		打分	打分	打分	
对需求的理解	15%	6	6	9	1.05
技术能力	15%				
全生命周期成本	20%				
管理水平	15%				
企业资质	15%				
经验	5%				
财务能力	10%				
其他	5%				
技术管理总分					该供应商的技术管理总分

对于大型的或重要采购事项，这一过程或招标评标过程可能要重复多次。通过这一过程的过滤，得到一个精简的、合格的卖方清单，然后根据更详细和全面的建议书展开更详细的评估，最后会挑出一个或若干个中标人。

14.4.8 相关法律责任

所谓法律责任，就是某人或某个单位等法律主体因自己的不当言行、或过失、或关联关系而承担的相应的行政责任、民事责任或刑事责任。

《中华人民共和国招标投标法》明确了招投标过程中涉及的各方的法律责任，涉及的各方有招标人、招标代理机构、投标人、评标委员会的专家、招标单位直接主管、中标人等。就投标人承担的法律责任来说，具体规定如下。

投标人相互串通投标或者与招标人串通投标的，投标人以向招标人或者评标委员会成员行贿的手段谋取中标的，中标无效，处中标项目金额千分之五以上千分之十以下的罚款，对单位直接负责的主管人员和其他直接责任人员处单位罚款数额百分之五以上百分之十以下的罚款；有违法所得的，并处没收违法所得；情节严重的，取消其一年至两年内参加依法必须进行招标的项目的投标资格并予以公告，直至由工商行政管理机关吊销营业执照；构成犯罪的，依法追究刑事责任；给他人造成损失的，依法承担赔偿责任。

投标人以他人名义投标或者以其他方式弄虚作假，骗取中标的，中标无效，给招标人造成损失的，依法承担赔偿责任；构成犯罪的，依法追究刑事责任。

14.5 控制采购

控制采购是管理采购关系、监督合同执行情况，并根据需要实施变更和采取纠正措施的过程。

买卖双方的任何一方都需要确保对方能正常履约，这样他们的合法权利就能得到维护，这就需要对合同的执行进行管理。

控制采购过程是买卖双方都需要的。该过程确保卖方的执行过程符合合同需求，确保买方可以按合同条款去执行。对于使用来自多个供应商提供的产品、服务或成果的大型项目来说，合同管理的关键是管理买方卖方间的接口，以及多个卖方间的接口。

控制采购的依据是项目管理计划、采购文件、合同及合同管理计划、绩效报告、已批准的变更申请、工作绩效报告和工作绩效信息，经过使用合同变更控制系统、买方主持的绩效评审、检查和审计、绩效报告、支付系统、索赔管理和自动的工具系统等工具和技术，顺利完成合同。

根据合同以及卖方当前的绩效水平，如合同的执行出现偏差，则需要制定纠正措施。如有合同更新，则提交更新后的合同及其相关文件。

在控制采购过程中，通过这种绩效审查，考察卖方在未来项目中执行类似工作的能力。

控制采购还包括记录必要的细节以管理任何合同工作的提前终止（因各种原因、求便利或违约）。这些细节会在结束采购过程中使用，以终止协议。

由于组织结构不同，许多卖方把合同管理当作与项目相分离的一种管理职能，比如法务部负责合同管理。来自法务部的采购管理员可以加入项目团队，但他通常向服务部的经理报告。

对于买方，合同管理也是交由类似法务部的职能部门管理。

在控制采购过程中，还需要其他项目管理过程配合，并把这些过程的输出整合进项目的整体管理中。

如果项目有多个卖方，涉及多个产品、服务或成果，这种整合通常需要在多个层次上进行。需要应用的项目管理过程包括（但不限于）：

- （1）指导与管理项目工作，授权卖方在适当时间开始工作；
- （2）控制质量，检查和核实卖方产品是否符合要求；
- （3）实施整体变更控制，确保合理审批变更，以及干系人员都了解变更的情况；
- （4）控制风险，确保减轻风险。

在控制采购过程中，还需要进行财务管理工作，监督向卖方的付款。卖方完成多少

工作，就付多少款项。

在合同收尾前，经双方共同协商，可以根据协议中的变更控制条款，及时对协议进行修改。这种修改通常都要书面记录下来。

对买方来说，控制采购过程的主要目标如下。

(1) 保证合同的有效执行。项目执行组织在采购合同签订后，应该定时监督和控制供应商的产品供货和相关的服务情况。要督促供应商按时提供产品和服务，保证项目的工期。

(2) 保证采购产品及服务质量的控制。为了保证这个项目所使用的各项物力、人力资源是符合预计的质量要求和标准的，项目执行组织应该对来自于供应商的产品和服务进行严格的检查和验收工作，可以在项目组织中设立质量小组或质量工程师，完成质量的控制工作。

14.5.1 控制采购的输入

项目管理计划、采购文件、合同、批准的变更请求、工作绩效报告和工作绩效数据等，是进行控制采购过程的前提。

1. 项目管理计划

采购管理计划包含在项目管理计划里，采购管理计划不仅为控制采购提供了依据，也为从编制采购文件到合同收尾的各采购过程提供了指南。

2. 采购文件

采购文件用来得到潜在卖方的报价建议书。典型的采购文件如投标邀标书（IFB）、建议邀请书（RFP）、报价邀请书（RFQ）和建议书等。

采购文件中包含管理各采购过程所需的各种支持性信息，如关于采购合同授予的规定和工作说明书，这些内容为控制采购提供了依据。

3. 合同

合同是买卖双方之间就采购工作达成的一致，包括对每一方的权力和义务的明确。同样，项目经理监控采购时要依据合同检查卖方的合同执行情况。

4. 批准的变更请求

批准的变更请求可能包括对合同条款和条件的修改。例如修改采购工作说明书、合同价格，以及对合同产品、服务或成果描述的修改，在把变更付诸实施前，所有与采购有关的变更都应该以书面形式正式记录并得到正式批准。

5. 工作绩效报告

与卖方绩效有关的文档包括：

(1) 技术文档。按照合同规定，由卖方编制的技术文件和其他可交付成果信息。

(2) 工作绩效信息。卖方的绩效报告会显示哪些可交付成果已经完成，哪些还没有完成。

6. 工作绩效数据

卖方的工作绩效数据包括：

- (1) 满足质量标准的程度；
- (2) 已发生或已承诺的成本；
- (3) 已付讫的卖方发票的情况。

所有这些数据都在项目执行中收集起来，这些数据就是工作绩效数据。

14.5.2 控制采购过程使用的工具与技术

1. 合同变更控制系统

在执行合同过程中，无论卖方还是买方，都有可能要调整合同内容，这涉及到了合同变更。

因此需要合同变更控制系统来规范合同变更，使修改合同的过程在买卖双方达成一致的前提下进行，合同里的变更条款为合同变更提供了指南。

合同变更控制系统包括：变更过程的书面记录工作、变更跟踪系统、变更争议解决程序，以及各种变更所需的审批层次。

合同变更往往涉及到项目的整体变更，因此合同变更控制系统应当与整体变更控制系统整合起来。

2. 检查与审计

在项目执行过程中，应该根据合同规定，由买方开展相关的检查与审计，卖方理应对此提供支持。

通过检查与审计，验证卖方的工作过程或可交付成果对合同的遵守程度。

如果合同条款允许，某些检查与审计团队中可以包括买方的采购人员。

3. 采购绩效审查

采购绩效审查是一种系统的、结构化的审查，买方依据合同来审查卖方在规定的成本和进度内完成项目范围和达到质量要求的情况。

采购绩效审查既包括对卖方所编文件的审查，也包括买方开展的检查，以及在卖方实施工作期间进行的质量审计。

绩效审查的目标在于发现履约情况的好坏、相对于采购工作说明书的进展情况，以及未遵循合同的情况，以便买方能够量化评价卖方在履行工作时所表现出来的能力。这些审查可能是项目状态审查的一个部分。在项目状态审查时，通常要考虑关键供应商的绩效情况。

4. 报告绩效

根据合同要求，评估卖方提供的工作绩效数据和工作绩效报告，形成工作绩效信息，并向买方管理层报告。报告绩效为管理层提供了卖方的执行信息，例如离合同目标多远？卖方正在如何实现合同目标？措施是否有效？

5. 支付系统

依据经检查核实后的卖方绩效，通常先由负责的项目团队成员证明卖方的工作合格，再通过买方的应付账款系统向卖方付款：依据合同卖方完成多少就付多少，支付过程要留下文字记录。

6. 索赔管理

在执行合同时，买卖双方立场不同，因此有时会出现双方不能就变更补偿达成一致的情况，甚至对变更是否已经发生都存在分歧，那么被请求的变更就成为有争议的变更或潜在的推定变更。

有争议的变更也称为索赔、争议或诉求。

在整个合同生命周期中，通常应该按照合同规定对索赔进行记录、处理、监督和管理。如果合同双方无法自行解决索赔问题，则需要按照合同中规定的替代争议解决（ADR）程序进行处理。

谈判是解决所有索赔和争议的首选方法。

7. 记录管理系统

合同的签订、执行、变更等工作涉及大量的款项，也涉及买卖双方的其他利益。出现争议时，“口说无凭”，口头的说法不会被采纳，因此要对采购过程进行书面记录。

项目经理采用记录管理系统来管理合同、采购文档和相关记录。

记录管理系统是一个自动化辅助工具，它包含一套特定的过程、相关的控制功能，它是项目管理信息系统的一部分。利用该系统，可以检索合同文件、过程记录以及往来函件。

14.5.3 控制采购的输出

1. 工作绩效信息

工作绩效信息中包括合同履行信息，便于买方预测特定可交付成果的完成情况，追踪特定可交付成果的接收情况。合同履行信息有助于改进与卖方（供应商）的沟通，使潜在问题得到迅速处理，令各方都满意。

工作绩效信息为发现当前或潜在问题提供依据，来支持可能的后续索赔或开展新的采购。通过报告供应商的绩效情况，买方能够加强对采购绩效的认识，从而有助于改进预测、风险管理和决策。绩效报告还有助于处理与供应商之间的纠纷。

2. 变更请求

在控制采购过程中，可能产生对项目管理计划及其子计划和其他组成部分的变更请求，如成本基准、进度基准和采购管理计划。应该由实施整体变更控制过程对变更请求进行处理、审查和批准。

已提出而未解决的变更，可能包括买方发出的指令或卖方采取的行动，而对方认为该指令或行动已构成对合同的推定变更。由于双方可能对推定变更存在争议并可能引起

一方向另一方索赔，所以通常应该在项目往来函件中对推定变更进行专门识别、记录和沟通。

3. 项目管理计划更新

在对采购进行控制时，可能需要调整项目管理计划，要更新的内容包括但不限于：

(1) 采购管理计划。需要更新采购管理计划，以反映影响采购管理的、已批准的变更请求，包括这些变更对成本或进度的影响。

(2) 进度基准。如果发生了对整体项目绩效有影响的进度延误，则可能需要更新进度基准，以反映当前的期望。

(3) 成本基准。如果发生了影响整个项目成本的变更，则可能需要更新成本基准，以反映当前的期望。

4. 项目文件更新

在管理项目采购时，会产生大量采购文档。这些采购文档可包括采购合同，以及起支持作用的全部进度文件、已提出但未批准的合同变更和已批准的变更请求。采购文档还包括任何由卖方编制的技术文档和其他工作绩效信息，如可交付成果、卖方绩效报告、担保文件、财务文件（含发票和付款记录）、与合同相关的检查结果等。

随着采购工作的推进，不仅会产生采购文档，也可能需要更新其他项目文件。

5. 组织过程资产更新

在进行采购监控时，可能需要更新的组织过程资产包括但不限于：

(1) 往来函件。涉及到合同条款和条件及其执行，往往要求买方与卖方之间的沟通要采用书面形式以有利于解决未来可能的纠纷，例如，对不良绩效提出警告、提出合同变更请求或者进行合同澄清等。往来函件中可包括关于买方审计与检查结果的报告，该报告指出了卖方需纠正的不足之处。除了合同规定应保留的文档外，双方还应完整、准确地保存关于全部书面和口头沟通及全部行动和决定的书面记录。

(2) 支付计划和请求。所有支付都应按合同条款和条件进行。

(3) 卖方绩效评估文件。卖方绩效评估文件由买方编制，记录卖方继续执行现有合同工作的能力，说明是否允许卖方承接未来项目的工作，或对卖方执行项目工作的绩效进行评价评级。这些文件可成为提前终止合同、收缴合同罚款，或者支付合同费用和奖金的依据。这些绩效评估的结果也应纳入相关的合格卖方清单中。

14.6 结束采购

结束采购是完结本次项目采购的过程。

完成每一次项目采购，都需要结束采购过程。它是项目收尾或者阶段收尾过程的一部分，它把合同和相关文件归档以备将来参考，因为项目收尾或者阶段收尾过程已核实

本阶段或本项目所有工作和项目可交付物是否是可接受的。

合同收尾过程也包括管理活动，如更新记录以反映最终结果、存档信息以便将来使用。合同收尾考虑了项目或者项目阶段适用的每个合同。在多阶段项目中，一份合同的条款可能仅仅适用于项目的特定阶段。在这些情况下，合同收尾过程只对适于项目本阶段的合同进行收尾。未解决的索赔可能在收尾之后提起诉讼。合同条款与条件可规定合同收尾的具体程序。

合同的提前终止是合同收尾的特殊情况，它产生于双方的协商一致、或一方违约、或者合同中提到了买方有权决定。合同的终止条款中明确了提前终止情况下各方的权利和责任。

基于合同条款与条件，出于某种原因或利益，买方可能有权利随时终止全部合同或者项目的一部分。然而，基于合同条款与条件，买方可能必须补偿卖方的前期准备，以及任何卖方已经完成和被验收的工作。

14.6.1 结束采购的输入

1. 项目管理计划

项目管理计划包含采购管理计划，它为结束采购提供了细节和指南。

2. 采购文件

为结束合同，需要收集全部采购文档，并建立索引和加以归档。有关合同进度、范围、质量和成本绩效的信息，以及全部合同变更文档、支付记录和检查结果，都要编入目录。这些信息可用于总结经验教训，并可为以后合同的承包商评价工作提供基础。

14.6.2 结束采购的工具与技术

结束采购的工具和技术有采购审计、采购谈判和记录管理系统。

1. 采购审计

从编制采购管理计划过程一直到结束采购过程的整个采购过程中，采购审计都对采购的完整过程进行系统的审查。采购审计的目标是找出本次采购的成功和失败之处，以供买方组织内的其他项目借鉴。

2. 采购谈判

在所有采购关系中，一个重要的目标是通过谈判公正地解决全部未解决事项、索赔和争议。如果通过直接谈判无法解决，则可以尝试替代争议解决（ADR）方法，如调解或仲裁。如果所有方法都失败了，就只能选择向法院起诉这种最不可取的方法。

3. 记录管理系统

记录管理系统是一种自动的工具系统，项目经理使用它来管理合同、记录合同执行情况、并把合同文件和往来函件存档，这也是结束采购过程的一项工作。

14.6.3 结束采购的输出

1. 结束的采购

买方（通常是其授权的采购管理员）向卖方发出关于合同已经完成的正式书面通知。对正式结束采购的要求，通常已在合同条款和条件中定义，并包括在采购管理计划中。

2. 组织过程资产更新

一个合同执行完毕，总会多多少少产生一些文档、数据、经验教训，这些新的知识财产要补充到卖方的组织过程资产里。总之，要更新的组织过程资产要素包括但是不限于如下方面。

（1）采购档案。一套完整的、带索引的合同文档（包括已结束的合同）。采购档案应该纳入最终的项目档案中。

（2）可交付物验收。买方通过其负责的合同管理人员，向卖方提供项目可交付物通过验收或没有通过验收的正式书面通知。在合同条款中定义了对项目可交付物正式验收的要求，以及如何处理不符合要求的项目可交付物的程序。

（3）经验教训文件。为了改进未来的采购，应详细记录经验教训，以利于未来的过程改进。

第 15 章 信息（文档）和配置管理

15.1 信息系统项目相关信息（文档）及其管理

15.1.1 信息系统项目相关信息（文档）

1. 信息系统项目相关信息（文档）含义

信息系统相关信息（文档）是指某种数据媒体和其中所记录的数据。它具有永久性，并可以由人或机器阅读，通常仅用于描述人工可读的东西。在软件工程中，文档常常用来表示对活动、需求、过程或结果，进行描述、定义、规定、报告或认证的任何书面或图示的信息（包括纸质文档和电子文档）。

2. 信息系统项目相关信息（文档）种类

软件文档分为三类：开发文档、产品文档、管理文档。

(1) 开发文档描述开发过程本身，基本的开发文档是：

- 可行性研究报告和项目任务书；
- 需求规格说明；
- 功能规格说明；
- 设计规格说明，包括程序和数据规格说明；
- 开发计划；
- 软件集成和测试计划；
- 质量保证计划；
- 安全和测试信息。

(2) 产品文档描述开发过程的产物，基本的产品文档包括：

- 培训手册；
- 参考手册和用户指南；
- 软件支持手册；
- 产品手册和信息广告。

(3) 管理文档记录项目管理的信息，例如：

- 开发过程的每个阶段的进度和进度变更的记录；
- 软件变更情况的记录；
- 开发团队的职责定义。

文档的质量可以分为四级：

(1) 最低限度文档（1级文档），适合开发工作量低于一个人月的开发者自用程序。该文档应包含程序清单、开发记录、测试数据和程序简介。

(2) 内部文档（2级文档），可用于没有与其他用户共享资源的专用程序。除1级文档提供的信息外，2级文档还包括程序清单内足够的注释以帮助用户安装和使用程序。

(3) 工作文档（3级文档），适合于由同一单位内若干人联合开发的程序，或可被其他单位使用的程序。

(4) 正式文档（4级文档），适合那些要正式发行供普遍使用的软件产品。关键性程序或具有重复管理应用性质（如工资计算）的程序需要4级文档。4级文档遵守 GB 8567 的有关规定。

15.1.2 信息系统项目相关信息（文档）管理的规则和方法

信息系统文档的规范化管理主要体现在文档书写规范、图表编号规则、文档目录编写标准和文档管理制度等几个方面。

1) 文档书写规范

管理信息系统的文档资料涉及文本、图形和表格等多种类型，无论是哪种类型的文档都应该遵循统一的书写规范，包括符号的使用、图标的含义、程序中注释行的使用、注明文档书写人及书写日期等。例如，在程序的开始要用统一的格式包含程序名称、程序功能、调用和被调用的程序、程序设计人等。

2) 图表编号规则

在管理信息系统的开发过程中用到很多的图表，对这些图表进行有规则的编号，可以方便图表的查找。图表的编号一般采用分类结构。根据生命周期法的5个阶段，可以给出如图15-1所示的分类编号规则。根据该规则，就可以通过图表编号判断该图表处于系统开发周期的哪一个阶段，属于哪一个文档，文档中的哪一部分内容及第几张图表。

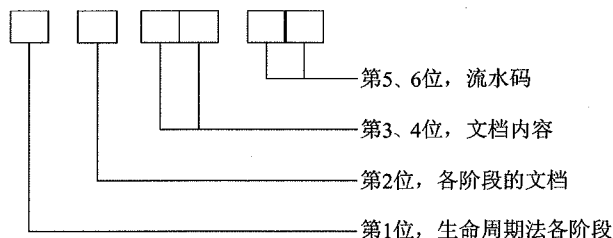


图 15-1 图表编号规则

3) 文档目录编写标准

为了存档及未来使用的方便，应该编写文档目录。管理信息系统的文档目录中应包含文档编号、文档名称、格式或载体、份数、每份页数或件数、存储地点、存档时间、保管人等。文档编号一般为分类结构，可以采用同图表编号类似的编号规则。文档名称

要完整规范。格式或载体指的是原始单据或报表、磁盘文件、磁盘文件打印件、大型图表、重要文件原件、光盘存档等。

4) 文档管理制度

为了更好地进行信息系统文档的管理，应该建立相应的文档管理制度。文档的管理制度需根据组织实体的具体情况而定，主要包括建立文档的相关规范、文档借阅记录的登记制度、文档使用权限控制规则等。建立文档的相关规范是指文档书写规范、图表编号规则和文档目录编写标准等。文档的借阅应该进行详细的记录，并且需要考虑借阅人是否有使用权限。在文档中存在商业秘密或技术秘密的情况下，还应注意保密。特别要注意的是，项目干系人签字确认后的文档要与相关联的电子文档一一对应，这些电子文档还应设置为只读。

15.2 配置管理

配置管理是为了系统地控制配置变更，在系统的整个生命周期中维持配置的完整性和可跟踪性，而标识系统在不同时间点上配置的学科。在 GB/T 11457-2006 中，将“配置管理”正式定义为：“应用技术的和管理的指导和监控方法以标识和说明配置项的功能和物理特征，控制这些特征的变更，记录和报告变更处理和实现状态并验证与规定的需求的遵循性。”

尽管硬件配置管理和软件配置管理的实现有所不同，配置管理的概念可以应用于各种信息系统集成项目。

配置管理包括 6 个主要活动：制定配置管理计划、配置标识、配置控制、配置状态报告、配置审计、发布管理和交付。

15.2.1 配置管理的概念

1. 配置项

GB/T 11457-2006 对配置项的定义为：“为配置管理设计的硬件、软件或二者的集合，在配置管理过程中作为一个单个实体来对待。”

以下内容都可以作为配置项进行管理：外部交付的软件产品和数据、指定的内部软件工作产品和数据、指定的用于创建或支持软件产品的支持工具、供方/供应商提供的软件和客户提供的设备/软件。典型配置项包括项目计划书、需求文档、设计文档、源代码、可执行代码、测试用例、运行软件所需的各种数据，它们经评审和检查通过后进入配置管理。

所有配置项都应按照相关规定统一编号，按照相应的模板生成，并在文档中的规定章节（部分）记录对象的标识信息。在引入配置管理工具进行管理后，这些配置项都应以一定的目录结构保存在配置库中。

在信息系统的开发流程中需加以控制的配置项可以分为基线配置项和非基线配置项两类，例如，基线配置项可能包括所有的设计文档和源程序等；非基线配置项可能包括项目的各类计划和报告等。

所有配置项的操作权限应由 CMO（配置管理员）严格管理，基本原则是：基线配置项向开发人员开放读取的权限；非基线配置项向 PM、CCB 及相关人员开放。

2. 配置项状态

配置项的状态可分为“草稿”“正式”和“修改”三种。配置项刚建立时，其状态为“草稿”。配置项通过评审后，其状态变为“正式”。此后若更改配置项，则其状态变为“修改”。当配置项修改完毕并重新通过评审时，其状态又变为“正式”。

配置项状态变化如图 15-2 所示。

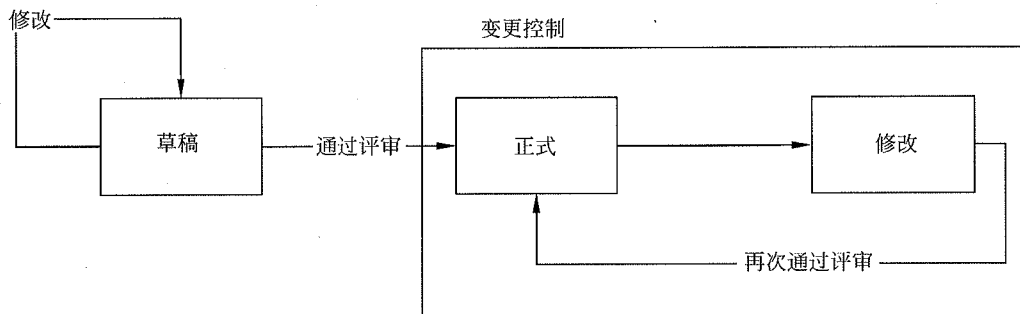


图 15-2 配置项状态变化

3. 配置项版本号

配置项的版本号规则与配置项的状态相关。

(1) 处于“草稿”状态的配置项的版本号格式为 0.YZ，YZ 的数字范围为 01~99。随着草稿的修正，YZ 的取值应递增。YZ 的初值和增幅由用户自己把握。

(2) 处于“正式”状态的配置项的版本号格式为 X.Y，X 为主版本号，取值范围为 1~9。Y 为次版本号，取值范围为 0~9。

配置项第一次成为“正式”文件时，版本号为 1.0。

如果配置项升级幅度比较小，可以将变动部分制作成配置项的附件，附件版本依次为 1.0, 1.1, ……。当附件的变动积累到一定程度时，配置项的 Y 值可适量增加，Y 值增加一定程度时，X 值将适量增加。当配置项升级幅度比较大时，才允许直接增大 X 值。

(3) 处于“修改”状态的配置项的版本号格式为 X.YZ。配置项正在修改时，一般只增大 Z 值，X.Y 值保持不变。当配置项修改完毕，状态成为“正式”时，将 Z 值设置为 0，增加 X.Y 值。参见上述规则 (2)。

4. 配置项版本管理

配置项的版本管理作用于多个配置管理活动之中，如配置标识、配置控制和配置审

计、发布和交付等。在项目开发过程中，绝大部分的配置项都要经过多次的修改才能最终确定下来。对配置项的任何修改都将产生新的版本。由于我们不能保证新版本一定比旧版本“好”，所以不能抛弃旧版本。版本管理的目的是按照一定的规则保存配置项的所有版本，避免发生版本丢失或混淆等现象，并且可以快速准确地查找到配置项的任何版本。

5. 配置基线

信息系统的开发过程是一个不断变化着的过程，为了在不严重阻碍合理变化的情况下来控制变化，配置管理引入了“配置基线（Configuration Baseline）”这一概念。

配置基线（常简称为基线）由一组配置项组成，这些配置项构成一个相对稳定的逻辑实体。基线中的配置项被“冻结”了，不能再被任何人随意修改。对基线的变更必须遵循正式的变更控制程序。

一组拥有唯一标识号的需求、设计、源代码文卷以及相应的可执行代码、构造文卷和用户文档构成一条基线。产品的一个测试版本（可能包括需求分析说明书、概要设计说明书、详细设计说明书、已编译的可执行代码、测试大纲、测试用例、使用手册等）是基线的一个例子。

基线通常对应于开发过程中的里程碑（Milestone），一个产品可以有多个基线，也可以只有一个基线。交付给外部顾客的基线一般称为发行基线（Release Baseline），内部开发使用的基线一般称为构造基线（Build Baseline）。

对于每一个基线，要定义下列内容：建立基线的事件、受控的配置项、建立和变更基线的程序、批准变更基线所需的权限。在项目实施过程中，每个基线都要纳入配置控制，对这些基线的更新只能采用正式的变更控制程序。

建立基线还可以有如下好处：

- （1）基线为开发工作提供了一个定点和快照。
- （2）新项目可以在基线提供的定点上建立。新项目作为一个单独分支，将与随后对原始项目（在主要分支上）所进行的变更进行隔离。
- （3）当认为更新不稳定或不可信时，基线为团队提供一种取消变更的方法。
- （4）可以利用基线重新建立基于某个特定发布版本的配置，以重现已报告的错误。

6. 配置库

配置库（Configuration Library）存放配置项并记录与配置项相关的所有信息，是配置管理的有力工具，利用库中的信息可回答许多配置管理的问题，例如：

- 哪些客户已提取了某个特定的系统版本；
- 运行一个给定的系统版本需要什么硬件和系统软件；
- 一个系统到目前已生成了多少个版本，何时生成的；
- 如果某一特定的构件变更了，会影响到系统的哪些版本；
- 一个特定的版本曾提出过哪几个变更请求；

- 一个特定的版本有多少已报告的错误。

使用配置库可以帮助配置管理员把信息系统开发过程的各种工作产品，包括半成品或阶段产品和最终产品管理得井井有条，使其不致管乱、管混、管丢。

配置库可以分为开发库、受控库、产品库 3 种类型。

(1) 开发库（Development Library），也称为动态库、程序员库或工作库，用于保存开发人员当前正在开发的配置实体，如：新模块、文档、数据元素或进行修改的已有元素。动态中的配置项被置于版本管理之下。动态库是开发人员的个人工作区，由开发人员自行控制。库中的信息可能有较为频繁的修改，只要开发库的使用者认为有必要，无需对其进行配置控制，因为这通常不会影响到项目的其他部分。

(2) 受控库（Controlled Library），也称为主库，包含当前的基线加上对基线的变更。受控库中的配置项被置于完全的配置管理之下。在信息系统开发的某个阶段工作结束时，将当前的工作产品存入受控库。

(3) 产品库（Product Library），也称为静态库、发行库、软件仓库，包含已发布使用的各种基线的存档，被置于完全的配置管理之下。在开发的信息系统产品完成系统测试之后，作为最终产品存入产品库内，等待交付用户或现场安装。

配置库的建库模式有两种：按配置项类型建库和按任务建库。

(1) 按配置项的类型分类建库，适用于通用软件的开发组织。在这样的组织内，产品的继承性往往较强，工具比较统一，对并行开发有一定的需求。使用这样的库结构有利于对配置项的统一管理和控制，同时也能提高编译和发布的效率。但由于这样的库结构并不是面向各个开发团队的开发任务的，所以可能会造成开发人员的工作目录结构过于复杂，带来一些不必要的麻烦。

(2) 按开发任务建立相应的配置库，适用于专业软件的开发组织。在这样的组织内，使用的开发工具种类繁多，开发模式以线性发展为主，所以就没有必要把配置项严格地分类存储，人为增加目录的复杂性。对于研发性的软件组织来说，采用这种设置策略比较灵活。

7. 配置库权限设置

配置库的权限设置主要是解决库内存放的配置项什么人可以“看”、什么人可以“取”、什么人可以“改”、什么人可以“销毁”等问题。

配置管理员负责为每个项目成员分配对配置库的操作权限，如表 15-1 所示。

表 15-1 配置库的操作权限

权 限	内 容
Rcad	可以读取文件内容，但不能对文件进行变更
Check	可使用[check in]等命令，对文件内容进行变更
Add	可使用[文件追加]，[文件重命名]，[删除]等命令
Destroy	有权进行文件不可逆毁坏，清除，[rollback]等命令

针对受控库，项目相关人员的操作权限通常设定如表 15-2 所示。

表 15-2 受控库的权限设置

人员		项目经理	项目成员	QA	测试人员	配置管理员
权限						
文档	Rcad	√	√	√	√	√
	Check	√	√	√	√	√
	Add	√	√	√	√	√
	Destroy	×	×	×	×	√
代码	Rcad	√	√	√	√	√
	Check	√	√	×	×	√
	Add	√	√	×	×	√
	Destroy	×	×	×	×	√

说明：√ 表示该人员具有相应权限，× 表示该人员没有相应权限

针对产品库，项目相关人员的操作权限通常设定如表 15-3 所示。

表 15-3 产品库的权限设置

Release（产品库）						
人员		项目经理	项目成员	QA	测试人员	配置管理员
权限						
Rcad		√	√	√	√	√
Check		√	√	√	√	√
Add		×	×	×	×	√
Destroy		×	×	×	×	√

说明：√ 表示该人员具有相应权限，× 表示该人员没有相应权限

8. 配置控制委员会

配置控制委员会（Configuration Control Board, CCB），负责对配置变更做出评估、审批以及监督已批准变更的实施。

CCB 建立在项目级，其成员可以包括项目经理、用户代表、产品经理、开发工程师、测试工程师、质量控制人员、配置管理员等。CCB 不必是常设机构，完全可以根据工作的需要组成，例如按变更内容和变更请求的不同，组成不同的 CCB。小的项目 CCB 可以只有一个人，甚至只是兼职人员。

通常，CCB 不只是控制配置变更，而是负有更多的配置管理任务，例如：配置管理计划审批、基线设立审批、产品发布审批等。

9. 配置管理员

配置管理员（Configuration Management Officer, CMO），负责在项目的整个生命周

期中进行配置管理活动，具体有：

- 编写配置管理计划；
- 建立和维护配置管理系统；
- 建立和维护配置库；
- 配置项识别；
- 建立和管理基线；
- 版本管理和配置控制；
- 配置状态报告；
- 配置审计；
- 发布管理和交付；
- 对项目成员进行配置管理培训。

10. 配置管理系统

配置管理系统是用来进行配置管理的软件系统，其目的是通过确定配置管理细则和提供规范的配置管理软件，加强信息系统开发过程的质量控制，增强信息系统开发过程的可控性，确保配置项（包括各种文档、数据和程序）的完备、清晰、一致和可追踪性，以及配置项状态的可控制性。

15.2.2 制定配置管理计划

配置管理计划是对如何开展项目配置管理工作的规划，是配置管理过程的基础，应该形成文件并在整个项目生命周期内处于受控状态。配置控制委员会负责审批该计划。

配置管理计划的主要内容为：

- （1）配置管理活动，覆盖的主要活动包括配置标识、配置控制、配置状态报告、配置审计、发布管理与交付；
- （2）实施这些活动的规范和流程；
- （3）实施这些活动的进度安排；
- （4）负责实施这些活动的人员或组织，以及他们和其他组织的关系。

15.2.3 配置标识

配置标识（Configuration Identification）也称配置识别，包括为系统选择配置项并在技术文档中记录配置项的功能和物理特征。

配置标识是配置管理员的职能，基本步骤如下：

- （1）识别需要受控的配置项；

- (2) 为每个配置项指定唯一性的标识号；
- (3) 定义每个配置项的重要特征；
- (4) 确定每个配置项的所有者及其责任；
- (5) 确定配置项进入配置管理的时间和条件；
- (6) 建立和控制基线；
- (7) 维护文档和组件的修订与产品版本之间的关系。

15.2.4 配置控制

配置控制即配置项和基线的变更控制，包括下述任务：标识和记录变更申请，分析和评价变更，批准或否决申请，实现、验证和发布已修改的配置项。

1. 变更申请

变更申请主要就是陈述：要做什么变更，为什么要做，以及打算怎么做变更。

相关人员如项目经理填写变更申请表，说明要变更的内容、变更的原因、受变更影响的关联配置项和有关基线、变更实施方案、工作量和变更实施人等，并提交给CCB。

2. 变更评估

CCB 负责组织对变更申请进行评估并确定以下内容。

- (1) 变更对项目的影响。
- (2) 变更的内容是否必要。
- (3) 变更的范围是否考虑周全。
- (4) 变更的实施方案是否可行。
- (5) 变更工作量估计是否合理。

CCB 决定是否接受变更，并将决定通知相关人员。

3. 通告评估结果

CCB 把关于每个变更申请的批准、否决或推迟的决定通知受此处置意见影响的每个干系人。

如果变更申请得到批准，应该及时把变更批准信息和变更实施方案通知给那些正在使用受影响的配置项和基线的干系人。

如果变更申请被否决，宜通知有关干系人放弃该变更申请。

4. 变更实施

项目经理组织修改相关的配置项，并在相应的文档或程序代码中记录变更信息。

5. 变更验证与确认

项目经理指定人员对变更后的配置项进行测试或验证。

项目经理应将变更与验证的结果提交 CCB，由其确认变更是否已经按要求完成。

6. 变更的发布

配置管理员将变更后的配置项纳入基线。

配置管理员将变更内容和结果通知相关人员，并做好记录。

7. 基于配置库的变更控制

信息系统在一处出现了变更，经常会连锁引起多处变更，会涉及到参与开发工作的许多人员。例如，测试引发了需求的修改，那么很可能要涉及到需求规格说明、概要设计、详细设计和代码等相关文档，甚至会使测试计划随之改变。

如果是多个开发人员对信息系统的同一部件做修改，情况会更加复杂。例如，在软件测试时发现了两个故障。项目经理最初以为两故障是无关的，就分别指定甲和乙去解决这两个故障。但碰巧，引起这两个故障的错误代码都在同一个软件部件中。甲和乙各自对故障定位后，先后从库中取出该部件，各自做了修改，又先后送回库中。结果，甲放入库中的版本只有甲乙的修改，乙放入库中的版本只有乙的修改，没有一个版本同时解决了两个故障。

基于配置库的变更控制可以完美地解决上述问题，如图 15-3 所示。

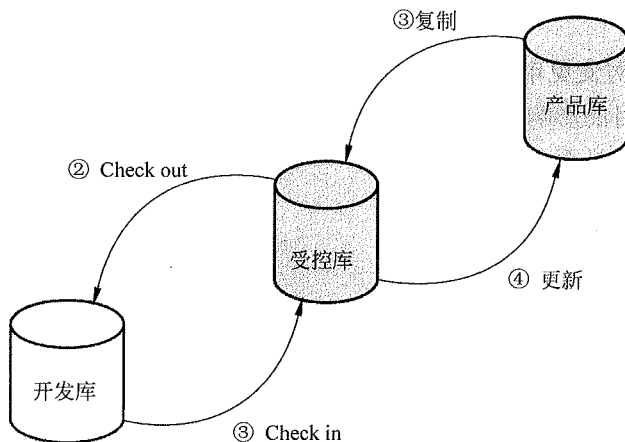


图 15-3 基于配置库的变更控制

现以某软件产品升级为例，简述其流程。

(1) 将待升级的基线（假设版本号为 V2.1）从产品库中取出，放入受控库。

(2) 程序员将欲修改的代码段从受控库中检出（Check out），放入自己的开发库中进行修改。代码被 Check out 后即被“锁定”，以保证同一段代码只能同时被一个程序员修改，如果甲正对其修改，乙就无法 Check out。

(3) 程序员将开发库中修改好的代码段检入（Check in）受控库。Check in 后，代码

的“锁定”被解除，其他程序员可以 Check out 该段代码了。

(4) 软件产品的升级修改工作全部完成后，将受控库中的新基线存入产品库中（软件产品的版本号更新为 V2.2，旧的 V2.1 版并不删除，继续在产品库中保存）。

15.2.5 配置状态报告

配置状态报告（Configuration Status Reporting）也称配置状态统计（Configuration Status Accounting），其任务是有效地记录和报告管理配置所需要的信息，目的是及时、准确地给出配置项的当前状况，供相关人员了解，以加强配置管理工作。

在信息系统项目开发过程中，配置项在不停地演化着。配置状态报告就是要在某个特定的时刻观察当时的配置状态，也就是要对动态演化着的配置项取某个瞬时的“照片”，以利于在状态报告信息分析的基础上，更好地进行控制。

配置状态报告应该包含以下内容：

(1) 每个受控配置项的标识和状态。一旦配置项被置于配置控制下，就应该记录和保存它的每个后继进展的版本和状态。

(2) 每个变更申请的状态和已批准的修改的实施状态。

(3) 每个基线的当前和过去版本的状态以及各版本的比较。

(4) 其他配置管理过程活动的记录。

配置状态报告应着重反映当前基线配置项的状态，以向管理者报告系统开发活动的进展情况。配置状态报告应定期进行，并尽量通过 CASE 工具自动生成，用数据库中的客观数据来真实地反映各配置项的情况。

配置状态报告中提供了许多有用的信息，可以用来回答如下问题：

(1) 程序 P13 的 1.6 版在哪个备份中可以使用？

(2) 在发行基线 5.1 和发行基线 5.2 之间实现了哪些变更请求？

(3) 在发行基线 5.2 中哪些程序更改过了？

(4) 在变更请求 671 中要对哪些配置项进行更改？在变更前和变更后，这些程序单元的版本是什么？是否所有的变更都完成并入库了？

配置状态报告还可供项目经理和 CCB 追踪变更的情况，可以用来回答如下问题：

(1) 某个变更请求是否已被批准？

(2) 某个已批准的变更请求目前处于什么状态？

(3) 某个已完成的变更投入了多少时间和工作量？

(4) 某个配置项与哪几个变更请求有关？

15.2.6 配置审计

配置审计（Configuration Audit）也称配置审核或配置评价，包括功能配置审计和物

理配置审计，分别用以验证当前配置项的一致性和完整性。

配置审计的实施是为了确保项目配置管理的有效性，体现了配置管理的最根本要求——不允许出现任何混乱现象，例如：

- 防止向用户提交不适合的产品，如交付了用户手册的不正确版本；
- 发现不完善的实现，如开发出不符合初始规格说明或未按变更请求实施变更；
- 找出各配置项间不匹配或不相容的现象；
- 确认配置项已在所要求的质量控制审核之后纳入基线并入库保存；
- 确认记录和文档保持着可追溯性。

1. 功能配置审计

功能配置审计（Functional Configuration Audit）是审计配置项的一致性（配置项的实际功效是否与其需求一致），具体验证以下几个方面。

- （1）配置项的开发已圆满完成。
- （2）配置项已达到配置标识中规定的性能和功能特征。
- （3）配置项的操作和支持文档已完成并且是符合要求的。

2. 物理配置审计

物理配置审计（Physical Configuration Audit）是审计配置项的完整性（配置项的物理存在是否与预期一致），具体验证如下几个方面。

- （1）要交付的配置项是否存在。
- （2）配置项中是否包含了所有必需的项目。

15.2.7 发布管理和交付

发布管理和交付活动的主要任务是：有效控制软件产品和文档的发行和交付，在软件产品的生存期内妥善保存代码和文档的母拷贝。

1. 存储

应通过下述方式确保存储的配置项的完整性：

- （1）选择存储介质使再生差错或损坏降至最低限度；
- （2）根据媒体的存储期，以一定频次运行或刷新已存档的配置项；
- （3）将副本存储在不同的受控场所，以减少丢失的风险。

2. 复制

复制是用拷贝方式制造软件的阶段。

应建立规程以确保复制的一致性和完整性。

应确保发布用的介质不含无关项（如软件病毒或不适合演示的测试数据）。

应使用适合的介质以确保软件产品符合复制要求，确保其在整个交付期中内容的完整性。

3. 打包

应确保按批准的规程制备交付的介质。

应在需方容易辨认的地方清楚地标出发布标识。

4. 交付

供方应按合同中的规定交付产品或服务。

5. 重建

应能重建软件环境，以确保发布的配置项在所保留的先前版本要求的未来一段时间里是可重新配置的。

第 16 章 变更管理

变更管理的大致作用与基本操作原则，已在整体管理（第 6 章）、范围管理（第 7 章）等相关章节中介绍。鉴于变更管理在项目管理中的重要性，本章对此专门进行论述。

变更在信息系统工程建设过程中经常发生，许多项目失败的原因就是由于对变更的处理不当。有些变更是积极的，有些则是消极的，做好变更管理可以使项目的质量、进度和成本管理更有效。

16.1 项目变更的基本概念

项目变更是指在信息系统项目的实施过程中，由于项目环境或者其他原因而对项目产品的功能、性能、架构、技术指标、集成方法、项目的范围基准、进度基准和成本基准等方面做出的改变。

变更管理的实质，是根据项目推进过程中越来越丰富的项目认知，不断调整项目努力方向和资源配置，最大程度地满足客户等相关干系人的需求，提升项目价值。

16.1.1 项目变更的含义

变更管理是为了使项目实际执行情况和项目基准相一致而对项目变更进行管理，其可能的结果是拒绝变更或调整基准。

从资源增值视角看，变更的实质是在项目过程中，按一定流程、根据变化了的情况更新方案、调整资源的配置方式或将储备资源运用于项目中，以满足客户等相关干系人的需求。

16.1.2 项目变更的分类

项目变更有多种分类方式，如：

- (1) 按变更性质分为重大变更、重要变更和一般变更，可通过不同审批权限控制。
- (2) 按变更的迫切性分为紧急变更和非紧急变更，可通过不同的变更处理流程进行控制。
- (3) 按变更所发生的领域和阶段，可分为进度变更、成本变更、质量变更、设计变更、实施变更和工作（产品）范围变更等。
- (4) 按变更来源可分为内部变更和外部变更等。

16.1.3 项目变更产生的原因

项目具有逐渐完善的基本特征，这就意味着早期的共识会随着对项目的逐步细化，在实施过程不可避免地发生变化。

与其他传统行业项目相比，系统集成项目往往涉及到软件系统，由于软件项目业务可见性比较差，用户在项目前期难以给出明确、具体的业务内容；另外，软件系统的修改更容易，所以，包含软件系统的系统集成项目所面临的变更往往更为频繁。而不加控制的变更也常常是项目失败的重要原因，正因如此，变更管理在系统集成项目中就显得尤为重要。

项目变更可能是产品范围发生了变化，即对交付物的需求发生了变化；也可能是项目范围发生了变化，或者是项目的资源、进度等执行过程发生了变化。

项目变更的原因很多，常见的有：

- (1) 产品范围（成果）定义的过失或者疏忽；
- (2) 项目范围（工作）定义的过失或者疏忽；
- (3) 客户提出新需求；
- (4) 应对风险的紧急措施或规避措施；
- (5) 项目执行过程与项目基准要求不一致带来的被动调整（如进度、质量、成本等）；
- (6) 项目团队人员调整；
- (7) 技术革新的要求；
- (8) 外部事件（例如政策变动或自然环境变化等）。

16.2 变更管理的基本原则

变更管理的基本原则是首先建立项目基准、变更流程和变更控制委员会（也叫变更管理委员会）。

1) 基准管理

基准是变更的依据。在项目实施过程中，制定基准计划并经过评审后即建立初始基准，此后应针对每次批准的变更重新确定基准。

2) 建立变更控制流程

建立或选用符合项目需要的变更管理流程后，所有变更都必须遵循这个流程进行控制。流程的作用在于将变更的原因、专业能力、资源运用方案、决策权、干系人的共识和信息流转等元素有效地综合起来，按科学的顺序进行变更。

3) 建立变更控制委员会

建立变更控制委员会并明确其职责，明确变更流程中相关工作的角色及其职责。

4) 完整体现变更的影响

变更的来源是多样的，既包括客户可见的工作成果、交付期等的变更，又包括客户不可见的项目内部工作的变更，如实施方的人员变更、内部管理变更等。各种来源的变更都可能会对项目的进度、成本、质量等产生影响，变更管理过程中需要全面完整地分析变更可能产生的影响，为变更控制提供依据。

5) 变更产生的相关文档应纳入配置管理中

可以使用手工或自动化工具进行配置管理，目前常用的配置管理工具有 Rational ClearCase、Perforce、CA CCC/Havest、Merant PVCS、Microsoft VSS、CVS 等，常用的开源免费的配置管理工具有 SVN、GIT、CVS 等。

16.3 变更管理角色职责与工作程序

变更管理的一般流程如图 16-1 所示，变更管理贯穿整个项目，其过程涉及到多种角色，下面说明变更管理涉及到的角色及其职责，以及变更管理的工作程序。

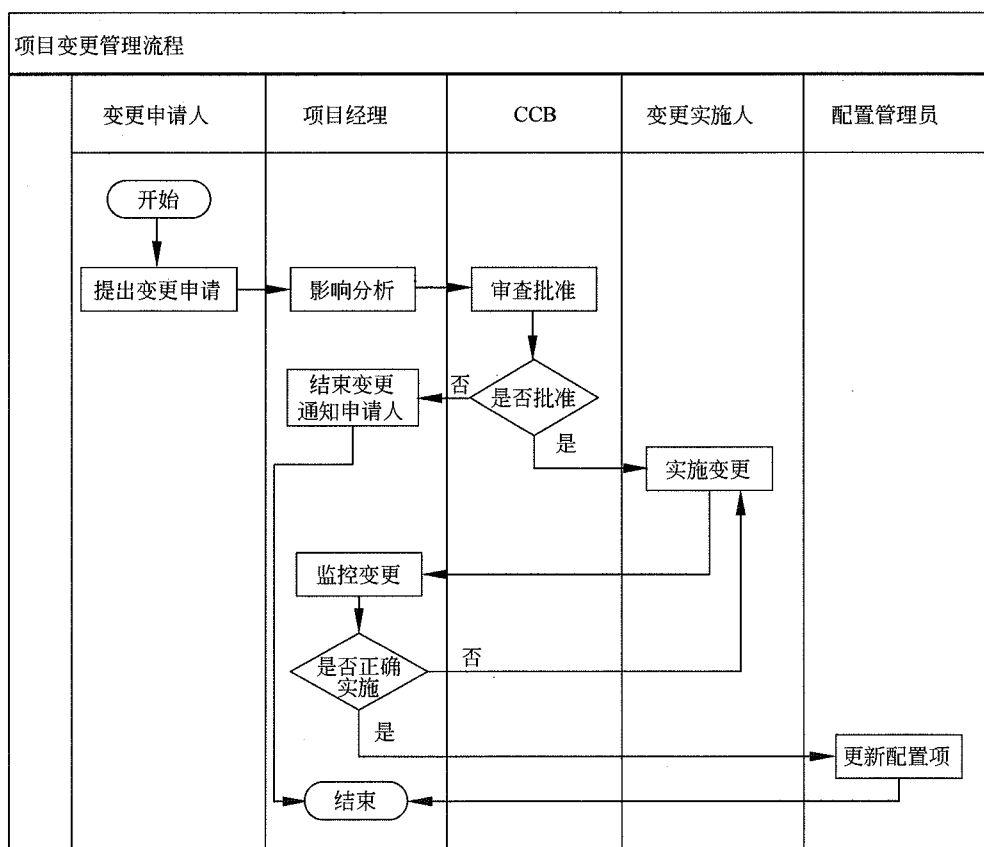


图 16-1 变更管理流程

16.3.1 角色职责

变更管理过程涉及到的角色主要包括项目经理、变更控制委员会、变更申请人、变更执行人以及配置管理员等。

1) 变更申请人

变更申请人是提出变更申请的相关人员，项目的任何干系人都可以提出变更申请，在系统集成项目中，项目变更申请人多是甲方项目负责人，变更申请多为项目范围变更、项目需求变更等，也有乙方项目经理在项目执行和监控过程中提出的变更申请。

变更申请人负责提交变更申请，必要时需要参与影响分析及变更方案制定，在变更结束后需要参与确认变更的正确性。

2) 项目经理

项目经理对项目负责，也对整个项目变更管理过程负责。

项目经理负责变更申请的影响分析，负责召开变更控制委员会会议，负责监控变更及已批准变更的正确实施等。

3) 变更控制委员会

变更控制委员会（Configuration Control Board, CCB）是一个正式的组织，负责审查、评价、批准、推迟或否决项目变更。CCB 由项目所涉及的多方人员共同组成，通常包括甲方和乙方的决策人员。

作为决策机构，CCB 在变更管理过程中负责对提交的变更申请进行审查，并对变更申请做出批准、否决或其他决定。

4) 变更实施人

变更实施人是实施已批准的变更的相关人员，变更申请内容不同，相应的变更实施人员也不同。

变更实施人负责执行已批准的变更，也要参与变更正确性的确认工作。

5) 配置管理员

变更过程的相关产物应纳入配置管理系统中。配置管理员负责把变更后的基准纳入整个项目基准中，变更过程中的其他记录文件也应纳入配置管理系统。

16.3.2 工作程序

如图 16-1 所示，变更管理的一般工作程序如下。

1) 提出变更申请

变更申请是关于修改文档、可交付物或基准的正式提议。变更申请被批准之后将会引起对相关文档、可交付物或基准的修改，也可能导致对项目管理计划其他相关部分的

更新。

如果在项目工作的实施过程中发现问题，就需要提出变更申请，对项目政策或程序、项目范围、项目成本或预算、项目进度计划或项目质量进行修改。其他变更申请包括必要的预防措施或纠正措施，用来防止以后的不利后果。变更申请可以是直接的或间接的，可以由外部或内部提出，可能是主动要求的或由法律/合同所强制的。

变更申请可能是：

- (1) 纠正措施。为了使项目工作绩效与项目管理计划保持一致而进行的变更申请。
- (2) 预防措施。为了确保项目工作的未来绩效符合项目管理计划而进行的变更申请。
- (3) 缺陷补救。为了修正不一致的产品或产品组件而进行的变更申请。
- (4) 更新。对正式受控的项目文件或计划等进行的变更申请，以便反映修改或增加的意见或内容。

所有变更申请都必须以书面形式记录，并纳入配置管理系统中。表 16-1 是一个软件需求变更申请表的例子，该需求变更申请表不仅包含了需求变更的内容，也反映了需求变更的工作程序，比如表中包含了变更影响分析、CCB 审批等。用表 16-1 提交变更申请则需要填写完整基本信息部分及变更申请内容部分。

表 16-1 需求变更申请表

需求变更申请表	
基本信息	
项目名称：	变更申请编号：
子系统名称：	要求完成日期： 年 月 日
有无附件： ☐ 会议纪要 ☐ 业务需求 ☐ 其它 ☐ 无	
阶段： ☐ 需求 ☐ 设计 ☐ 编码 ☐ 测试	
变更申请人：	申请人所属部门及职位：
变更申请日期：	年 月 日
1 变更申请内容	
1.1 变更内容描述	1.2 变更规模评价（功能点 FP）
1.3 变更类型选择 ☐ 新增功能 ☐ 修改原有功能 ☐ 删除现有功能	1.4 业务变更必要性评价 ☐ 必须修改 ☐ 强烈建议修改 ☐ 最好修改
1.5 结合所选择的业务变更必要性评价，具体陈述修改对业务可能产生的正面影响	1.6 结合所选择的业务变更必要性评价，具体陈述如果不能实施建议的修改对业务可能产生的负面影响
2 技术可行性分析	
2.1 技术可行性评审意见 ☐ 可行 ☐ 不可行	2.2 技术实施方案简单描述（可选）：

续表

需求变更申请表	
基本信息	
项目名称:	变更申请编号:
子系统名称:	要求完成日期: 年 月 日
有无附件: ☐ 会议纪要 ☐ 业务需求 ☐ 其它 ☐ 无	
阶段: ☐ 需求 ☐ 设计 ☐ 编码 ☐ 测试	
变更申请人:	申请人所属部门及职位:
变更申请日期: 年 月 日	
3. 变更对进度的影响 (天)	
3.1 列出实施需求变更所需额外的活动及其对应的预估时间 (天数)	3.2 变更导致项目额外活动的工期总和 (天数)
3.3 如有活动位于关键路径上, 描述变更对于关键路径的影响 (天数)	
4. 变更对成本的影响 (元)	
4.1 项目组需要额外的人员数目	4.2 直接人力成本 (人时)
4.3 人时工资率 (元)	4.4 人力成本分摊系数 (一般介于 2~3)
4.5 费用合计 (元)	
5.变更对质量的影响	
5.1 变更对质量的影响级别 ☐ 质量严重下降, 系统不稳定等 ☐ 质量明显下降, 功能使用受到影响或者性能明显下降 ☐ 质量可能下降, 对功能和性能有一定影响, 可能出现质量问题	5.2 变更可能造成的质量问题的具体描述 质量问题 1: 质量问题 2: 质量问题 3:
5.3 变更导致受影响的需求百分比例: 变更导致的需求缺陷个数:	5.4 变更导致受影响的设计百分比例: 变更导致的设计缺陷个数:
5.5 变更导致受影响的代码百分比例: 变更导致的代码缺陷个数:	5.6 变更导致受影响的测试用例百分比例: 变更导致的测试缺陷个数:
5.7 变更导致的试运行阶段缺陷个数:	
6 变更引起的风险	
6.1 变更引起的风险级别 ☐ 高级别风险 ☐ 中等级别风险 ☐ 低级别风险	6.2 风险的具体描述以及可能造成的负面后果
7 CCB 审核	
7.1 CCB 对变更的意见 ☐ 批准 ☐ 否决 ☐ 搁置	7.2 意见补充:
7.3 CCB 签字 CCB 组长签字: CCB 成员签字:	
日期: 年 月 日	

2) 变更影响分析

项目经理在接到变更申请以后，首先要检查变更申请中需要填写的内容是否完备，然后对变更申请进行影响分析。变更影响分析由项目经理负责，项目经理可以自己或指定人员完成，也可以召集相关人员讨论完成。

对于表 16-1 的需求变更申请，变更影响分析部分包括 2、3、4、5、6，分析内容包括技术可行性、对进度的影响、对成本的影响、对质量的影响以及变更风险分析，经过全面分析并记录相关信息，作为 CCB 决策的参考依据。

3) CCB 审查批准

变更申请人提交的每个变更申请都必须由一位责任人批准或否决，这个责任人通常是项目发起人或项目经理。必要时，应由变更控制委员会（CCB）进行审查批准。

CCB 对变更申请内容及其相关影响分析进行审查，并作出最后决策。CCB 审查可以通过文档会签的形式，也可以召开正式会议。CCB 对变更申请的决策可以是批准、否决或延期，也可以要求补充材料。

对于表 16-1 中的需求变更申请，需要 CCB 填写审核意见，并签字确认。

若 CCB 批准变更申请，则进入下一工作程序，即实施变更。

4) 实施变更

实施变更即执行变更申请中的变更内容。项目经理负责整合变更所需资源，合理安排变更，对于不同的变更申请，涉及到的变更实施人员也不同。

表 16-1 的需求变更申请，若是在需求基准刚建立的阶段提出的变更，则需求变更的实施人员就是需求分析人员，需要修改需求文档，若此变更涉及到进度、成本等其他基准的变更，也需要做相关修改。若需求变更申请在编码阶段提出来并获得了批准，那么实施变更时涉及的人员就比较广，包括需求人员、设计人员、编码人员等。

5) 监控变更实施

批准的变更进入实施阶段后，需要对它们的执行情况进行确认，以保证批准的变更都得到正确的落实，即需要对变更实施进行监控。

监控过程中除了对调整过的项目基准中所涉及的变更内容进行监控外，还应当对项目的整体基准是否反映项目实施情况进行监控。

通过对变更实施的监控，确认变更是否正确完成，对于正确完成的变更，需纳入配置管理系统中，没有正确实施的变更则继续进行变更实施。

6) 结束变更

变更申请被否决时变更结束，项目经理通知相关变更申请人。

批准的变更被正确完成后，成果纳入配置管理系统中并通知相关受影响人员，变更结束。

16.4 变更管理相关事项

16.4.1 变更管理操作要点

变更的实际情况千差万别，可能简单，也可能相当复杂。越是大型的项目，调整项目基准的边际成本越高，随意调整可能带来的麻烦也越多，可能导致基准失效、项目干系人冲突、资源浪费和项目执行情况混乱等。

在项目整体压力较大的情况下，更需强调变更管理的规范化，可以使用分批处理、分优先级处理等方式提高效率，如同繁忙的交通道口，如果红绿灯变化频繁，其结果不是灵活高效，而是整体通过能力的降低。

项目规模小、与其他项目的关联度小时，变更的提出与处理过程可在操作上力求简便、高效，但仍应注意以下几点：

(1) 对变更产生的因素施加影响，防止不必要的变更，减少无谓的评估，提高必要变更的通过效率。

(2) 变更的操作过程应当规范化。

(3) 对变更的确认应当正式化。

16.4.2 变更管理和整体管理及配置管理的关系

变更管理是项目整体管理的一部分，属于项目整体变更控制的范畴。因变更管理涉及范围、进度、成本、质量、人力资源和合同管理等多个方面，且其重要性不可忽视，故在本章单独说明。

配置管理重点关注可交付产品（包括中间产品）及各过程文档，而变更管理则着眼于识别、记录、批准或否决对项目文件、可交付产品或基准的变更。

变更管理过程中包含的部分配置管理活动如下。

(1) 配置项识别。识别与选择配置项，从而为核实产品配置、标记产品和文件、管理变更和明确责任提供基础。

(2) 配置状态记录。为了能及时提供关于配置项的准确数据，应记录和报告配置项的相关信息。此类信息包括变更控制中的已批准的配置项清单、变更申请的状态和已批准变更的实施状态。

(3) 配置确认与审计。通过配置确认与配置审计，可以保证项目各配置项组成的正确性，以及相应的变更都被登记、评估、批准、跟踪和正确实施，从而确保配置文件所规定的功能要求都已实现。

第 17 章 信息系统安全管理

17.1 信息安全管理

17.1.1 信息安全含义及目标

1. 信息安全定义

现代社会已经进入了信息时代，其突出的特点表现为信息的价值在很多方面超过其信息处理设施包括信息载体本身的价值，例如一台计算机上存储和处理的信息价值往往超过计算机本身的价值。另外，现代社会的各类组织，包括政府、企业，对信息以及信息处理设施的依赖也越来越大，一旦信息丢失或泄密、信息处理设施中断，很多政府及企事业单位的业务也就无法运营了。

现代信息社会对于信息的安全提出了更高的要求，对信息安全的内涵也不断进行延伸和拓展。国际标准 ISO/IEC 27001: 2013《信息技术-安全技术-信息安全管理体系-要求》标准中给出目前国际上的一个公认的信息安全的定义：“保护信息的保密性、完整性、可用性；另外也包括其他属性，如：真实性、可核查性、不可抵赖性和可靠性。”

2. 信息安全属性及目标

(1) 保密性 (Confidentiality)，是指“信息不被泄露给未授权的个人、实体和过程或不被其使用的特性。”简单地说，就是确保所传输的数据只被其预定的接收者读取。保密性的破坏有多种可能，例如，信息的故意泄露或松懈的安全管理。数据的保密性可以通过下列技术来实现：

- 网络安全协议；
- 身份认证服务；
- 数据加密。

(2) 完整性 (Integrity)，是指“保护资产的正确和完整的特性。”简单地说，就是确保接收到的数据就是发送的数据。数据不应该被改变，这需要某种方法去进行验证。确保数据完整性的技术包括：

- CA 认证；
- 数字签名；
- 防火墙系统；
- 传输安全 (通信安全)；

- 入侵检测系统。

(3) 可用性 (Availability), 是指“需要时, 授权实体可以访问和使用的特性。”可用性确保数据在需要时可以使用。尽管传统上认为可用性并不属于信息安全的范畴, 但随着拒绝服务攻击的逐渐盛行, 要求数据总能保持可用性就显得十分关键了。一些确保可用性的技术如以下几个方面:

- 磁盘和系统的容错;
- 可接受的登录及进程性能;
- 可靠的功能性的安全进程和机制;
- 数据冗余及备份。

保密性、完整性和可用性是信息安全最为关注的三个属性, 因此这三个特性也经常被称为信息安全三元组, 这也是信息安全通常所强调的目标。

(4) 其他属性及目标。另外, 信息安全也关注一些其他特性: 真实性一般是指对信息的来源进行判断, 能对伪造来源的信息予以鉴别; 可核查性是指系统实体的行为可以被独一无二地追溯到该实体的特性, 这个特性就是要求该实体对其行为负责, 可核查性也为探测和调查安全违规事件提供了可能性; 不可抵赖性是指建立有效的责任机制, 防止用户否认其行为, 这一点在电子商务中是极其重要的; 而可靠性是指系统在规定的时间内和给定的条件下, 无故障地完成规定功能的概率, 通常用平均故障间隔时间 (Mean Time Between Failure, MTBF) 来度量。

信息安全已经成为一门涉及计算机科学、网络技术、通信技术、密码技术、信息安全技术、应用数学、数论和信息论等多种学科的综合性学科。从广义上来说, 凡是涉及网络上信息的保密性、完整性、可用性、真实性和可核查性的相关技术和理论都属于信息安全的研究领域。

17.1.2 信息安全管理的内容

ISO/IEC 27000 系列标准是由国际标准组织与国际电工委员会共同发布的国际公认的信息安全管理系列标准, 它包括 ISO/IEC 27001《信息技术-安全技术-信息安全管理体系-要求》、ISO/IEC 27002《信息技术-安全技术-信息安全管理体系-实践准则》等系列标准。ISO/IEC 27000 系列标准是当前全球业界信息安全管理实践的最新总结, 为各种类型的组织引进、实施、维护和改进信息安全管理提供了最佳实践和评价规范。

在 ISO/IEC 27000 系列标准中, 它将信息安全管理的内容主要概括为如下 14 个方面。

1. 信息安全方针与策略

为信息安全提供管理指导和支持, 并与业务要求和相关的法律法规保持一致。管理者应根据业务目标制定清晰的方针和策略, 并通过在整个组织中颁发和维护信息安全方针来表明对信息安全的支持和承诺。

2. 组织信息安全

要建立管理框架，以启动和控制组织范围内的信息安全的实施。

管理者应批准整个组织内的信息安全方针、分配安全角色并协调和评审安全的实施。需要时，在组织范围内建立信息安全专家库，发展与外部安全专家或组织（包括相关政府机构）的联系，以便跟上行业发展趋势、跟踪标准和评估方法，并在处理信息安全事件时，提供合适的联络渠道，并鼓励多学科的信息安全方法。

同时要保持被外部组织访问、处理、通信或受其管理的组织信息及信息处理设施的安全。组织的信息处理设施和信息资产的安全不应由于引入外部各方的产品或服务而降低。任何外部各方对组织信息处理设施的访问、对信息资产的处理和通信都应予以控制。若业务上需要与外部各方一起工作从而要求访问组织的信息和信息处理设施，或从外部各方获得产品或服务、或向外部各方提供产品和服务时，就需要进行风险评估，以确定安全隐患和控制要求。在与外部各方签订的合同中要定义和商定控制措施。

对于所有项目，无论其特征是什么，例如核心业务过程、IT、设施管理和其他支持过程等方面的项目。信息安全应整合到组织的项目管理方法中，以确保识别并处理了信息安全风险。

应确保在使用移动计算和远程工作设施时的信息安全。所要求的保护应与那些特定工作方法引起的风险相匹配。当使用移动计算时，应考虑不受保护的环境中的工作风险，并且要应用合适的保护。在远程工作的情况下，组织要把保护应用于远程工作场地，并且对这种工作方式提供合适的安排。

3. 人力资源安全

要确保员工、合同方和第三方用户了解他们的责任并适合其岗位，从而减少盗窃、滥用或设施误用的风险。应在雇佣前就在岗位描述、雇用条款和条件中明确安全职责。所有的应聘人员，包括员工、合同方和第三方用户，特别是敏感岗位的人员，应进行充分的筛查。员工、合同方和信息处理设施的第三方用户均应就其安全角色和职责签署协议。

应确保所有的员工、合同方和第三方用户了解信息安全威胁和关注点，以及他们的责任和义务，并能够在他们的日常工作中支持组织的信息安全方针，减少人为错误的风险。应确定管理职责来确保安全应用于组织内个人的整个雇佣期。为尽可能减小安全风险，应对所有雇员、合同方和第三方用户提供关于安全程序以及正确使用信息处理设施的意识、教育和培训。并针对信息安全违规事件建立正式的处罚过程。

最后，要确保员工、合同方和第三方用户以一种有序的方式离开组织或工作变更。应建立职责确保员工、合同方和第三方用户的离开组织是受控的，并确保他们已归还所有设备并删除所有的访问权限。对于组织内的职责或工作变更也应参照上述做法实行类似管理。

4. 资产管理

要对组织资产实现并维持适当的保护。

所有资产均应有人负责，并有指定的所有者。对于所有资产均要识别所有者，并且要赋予维护相应控制的职责。具体控制的实施可以由所有者委派适当的人员承担，但所有者仍拥有对资产提供适当保护的责任。

要确保信息可以得到适当程度的保护。

应对信息进行分类，以便在信息处理时指明保护的需求、优先级和期望程度。信息的敏感度和关键度是可变的。某些信息可能需要额外的保护或特别的处理。应使用信息分类机制来定义适宜的保护水准和沟通特别处理措施的需求。

5. 访问控制

对信息、信息处理设施和业务过程的访问应基于业务和安全需求进行控制。访问控制规则应考虑到信息分发和授权的策略。

应确保授权用户对信息系统的访问，并防止非授权访问。应有正式的程序来控制对信息系统和服务的访问权限的分配和注销。这些程序应覆盖用户访问生命周期内的所有阶段，从新用户注册到不再要求访问信息系统和服务的用户的最终注销。适宜时，应特别注意对有特权的访问权限的分配的控制需求，这种权限允许用户超越系统控制。

应防止未授权的用户访问，以及信息和信息处理设施的破坏或被盗。授权用户的合作是有效安全的基础。用户应清楚其对维护有效的访问控制的职责，特别是关于口令使用和用户设备安全的职责。应实施桌面清空和屏幕清空策略以减少对纸质文件、介质和信息处理设施的未授权访问或破坏的风险。

防止对网络服务未经授权的访问。对内部和外部网络服务的访问均应加以控制。访问网络和网络服务的用户不应损害网络服务的安全，应确保：

- (1) 在本组织的网络和其他组织拥有的网络或公共网络之间有合适的分界。
- (2) 对用户和设备采用合适的认证机制。
- (3) 对用户访问信息服务的控制。

应防止对操作系统的未授权访问。应采用安全设施来限制授权用户访问操作系统。这些设施应能：

- (1) 按照确定的访问控制策略认证授权用户。
- (2) 记录成功和失败的系统认证尝试。
- (3) 记录专用系统特权的使用。
- (4) 当违背系统安全策略时发布警报。
- (5) 提供合适的认证手段。
- (6) 适宜时可限制用户的连接时间。

应防止对应用系统中信息的未授权访问。应采用安全设施限制对应用系统的访问以及应用系统内部的访问。对应用软件和信息的逻辑访问应只限于授权的用户。应用系统

应限于：

(1) 按照定义的访问控制策略，控制用户访问信息和应用系统功能。

(2) 防止能够越过系统控制或应用控制的任何实用程序、操作系统软件和恶意软件进行未授权访问。

(3) 不损坏与其共享信息资源的其他系统的安全。

应确保系统文档的安全。要控制对系统文档和程序源代码的访问，并且 IT 项目和支持活动应以安全的方式进行。应注意不能泄露测试环境中的敏感数据。

6. 密码

应通过加密手段来保护信息的保密性、真实性或完整性。应该制定使用密码的策略。应有密钥管理以支持密码技术的使用。

7. 物理和环境安全

应防止对组织办公场所和信息的非授权物理访问、破坏和干扰。关键或敏感的信息处理设施要放置在安全区域内，并受到确定的安全边界的保护，包括采用适当的安全屏障和入口控制。这些设施要在物理上避免未授权的访问、损坏和干扰。所提供的保护要与所识别的风险相匹配。

应防止资产的丢失、损坏、被盗和破坏，以及对组织业务活动的中断。应保护设备免受物理和环境的威胁。要对设备（包括非公司现场的设备和迁出的设备）进行保护以减少未授权访问信息的风险并防止丢失或损坏，同时要考虑设备安置和处置。可能需要专门的控制措施来防止物理威胁以及保护支持性设施，诸如电源供应和电缆基础设施。

8. 运行安全

确保信息处理设施的正确和安全操作。应建立所有信息处理设施的管理和操作的职责与程序，包括建立适宜的操作程序。适宜时，应实施职责分离，以减少疏忽或故意误用系统的风险。

应最小化系统失效的风险。为确保有足够能力和足够的资源的可用性提供给所需的系统性能，需要预先的策划和准备。应做出对于未来容量需求的规划，以减少系统过载的风险。在新系统验收和使用之前，要建立该新系统的运行要求，并形成文件，进行测试。

应保护软件和信息完整性。要求有预防措施，以防范和探测恶意代码和未授权的移动代码的引入。软件和信息处理设施容易受到恶意代码（例如计算机病毒、网络蠕虫、特洛伊木马和逻辑炸弹）的攻击。要让用户意识到恶意代码的危险。适用时，管理者要引入控制，以防范、探测并删除恶意代码，控制移动代码。

应保持信息 and 信息处理设施的完整性和可用性。应建立例行程序来执行商定的针对数据备份以及及时恢复演练的备份策略和战略。

应探测未经授权的信息处理活动。应监视系统并记录信息安全事件。应使用操作员日志和故障日志以确保识别出信息系统的问题。一个组织的监视和日志记录活动应遵守

所有相关法律的要求。应通过监视系统来检查所采用控制措施的有效性，并验证与访问策略模型的一致性。

应维护应用系统软件和信息的安全。应严格控制项目和支持环境。负责应用系统的管理人员也应负责项目和支持环境的安全。他们应确保评审所有提出的系统变更，以检验这些变更既不损坏该系统也不损害操作环境的安全。

应减少由利用已发布的技术漏洞带来的风险。应该以一种有效的、系统的、可重复的方式进行技术漏洞管理，同时采取测量以确定其有效性。这些考虑应包括在用的操作系统和应用系统。

涉及运行系统验证的审计要求和活动，应谨慎地加以规划并取得批准，以便最小化业务过程的中断。

9. 通信安全

应确保网络中的信息和支持性基础设施得到保护。网络安全管理可能会跨越组织边界，需要仔细考虑数据流动、法律要求、监视和保护。在数据通过公共网络进行传输时要提供额外的保护。

应防止对资产的未授权泄露、修改、移动或损坏，及对业务活动的中断。应控制介质，并对其实施物理保护。应建立适当的操作程序以保护文件、计算机介质（如磁带、磁盘）、输入输出数据和系统文档免遭未授权的泄露、修改、删除或破坏。

应维持组织内部或组织与外部组织之间交换信息和软件的安全。组织间信息和软件的交换应基于一个正式的交换策略，按照交换协议执行，还应服从相关的法律。应建立程序和标准，以保护传输中的信息和包含信息的物理介质。

10. 信息系统的获取、开发和保持

应确保安全成为信息系统的一部分。信息系统包括操作系统、基础设施、业务应用、非定制的产品、服务和用户开发的应用软件。支持业务过程的信息系统的设计和实施对安全来说是至关重要的。在信息系统开发或实施之前应识别并商定安全要求。所有安全需求应在项目的需求阶段予以识别，证实其合理性，达成一致，并形成文档，作为信息系统整个业务案例的一部分。

应防止应用系统中信息的错误、丢失、未授权的修改或误用。应用系统（包括用户开发的应用）内应设计合适的控制以确保处理的正确性。这些控制应包括输入数据、内部处理和输出数据的确认。对于处理敏感的、有价值的或关键的信息的系统或对上述信息有影响的系统可以要求附加控制。应基于安全需求和风险评估来确定这些控制措施。

应为系统开发全生命周期的开发和集成活动建立安全开发环境，并予以适当保护。安全的开发环境包括与系统开发和集成相关的人员、过程和技术。

应保护在公共网络上应用服务传输的信息，以防止遭受欺诈、合同纠纷以及未经授权的泄露和修改。

应确保电子商务的安全及其安全使用。应考虑与使用电子商务服务包括在线交易相

关的安全要求和控制措施要求。还应考虑通过公开可用系统以电子方式发布的信息的完整性和可用性。

11. 供应商关系

为降低供应商访问组织资产的相关风险，应与供应商就信息安全要求达成一致，并形成文件。供应商协议应包括信息与通信技术服务以及产品供应链相关的信息安全风险处理要求。应按照第三方服务交付协议的要求实施并保持信息安全和服务交付的适宜水平。组织应检查协议的实施，监视协议执行的一致性，并管理变更，以确保交付的服务满足与第三方商定的所有要求。

12. 信息安全事件管理

确保与信息系统有关的安全事件和弱点以一种能够及时采取纠正措施的方式进行沟通。应具有正式的事件报告和升级程序，所有的员工、合同方和第三方用户都应该知道这套报告不同类别的事件和弱点的程序，而这些事件和弱点组织的资产安全可能具有影响。应要求他们尽可能快地将信息安全事件和弱点报告给指定的联系点。联系点应根据商定的信息安全事态和事件分级准则评估每个信息安全事态，并决定该事态是否该归为信息安全事件。

应确保使用一致、有效的方法管理信息安全事件。应建立职责和程序以有效地处理报告的信息安全事件和弱点。对信息安全事件的响应、监视、评估和总体管理应进行持续的改进。需要证据时，证据的收集应符合法律的要求。

13. 业务持续性管理

应防止业务活动的中断，保护关键业务流程不会受到重大的信息系统失效或灾难的影响并确保它们的及时恢复。应实施业务持续性管理过程以减少对组织的影响，并通过预防和恢复控制措施的结合将信息资产的损失（例如，它们可能是灾难、事故、设备故障和故意行动的结果）恢复到可接受的程度。这个过程需要识别关键的业务过程，并将业务持续性的信息安全管理要求与其他的诸如运营、员工安置、材料、运输和设施等持续性要求予以整合。灾难、安全失效服务丢失和服务可用性的后果应取决于业务影响分析。应建立和实施业务持续性计划，以确保基本运营能及时恢复。信息安全应该是整体业务持续性过程和组织内其他管理过程的一个不可或缺的部分。除了通用的风险评估过程外，业务连续性管理应包括识别和减少风险的控制措施、降低有害事件的影响以及确保业务过程需要的信息能够随时得到。

14. 符合性

应避免违反法律、法规、规章、合同要求和其他的安全要求。信息系统的设计、运行、使用和管理都要受到法律法规要求的限制，以及合同安全要求的限制。应从组织的法律顾问或者合格的法律从业人员处获得关于特定的法律要求方面的建议。法律要求因国家而异，而且对于在一个国家所产生的信息发送到另一国家（即越境的数据流）的法律要求也不相同。

确保系统符合组织安全策略和标准。应定期评审信息系统的安全。这种评审应根据相应的安全策略和技术平台进行,而对信息系统也应进行审核,看其是否符合安全实施标准和形成文件的安全控制要求。

应最大化信息系统审核的有效性,并最小化来自信息系统审核带来的干扰。在审核过程中应有控制措施作用于操作系统和审核工具。也要保护审计工具的完整性并防止其被误用。

上面14个方面是ISO/IEC 27000系列标准中提出的信息安全管理的主要内容,当然,信息安全风险管理也是信息安全管理的重要基础,不管对于哪个方面控制措施的选择和评价,都应基于风险评价的结果进行。随着多学科的应用和相互融合,信息安全管理的內容也更加广泛和深入。

17.2 信息系统安全

17.2.1 信息系统安全概念

信息系统是指由计算机及其相关和配套的设备、设施构成的,按照一定的应用目标和规则对信息进行存储、传输、处理的系统或者网络。

而信息系统安全是指信息系统及其所存储、传输和处理的信息的保密性、完整性和可用性的表征,一般包括保障计算机及其相关的和配套的设备、设施(含网络)的安全,运行环境的安全,保障信息的安全,以保障信息系统功能的正常发挥,以维护信息系统的安全运行。

信息系统安全的侧重点会随着信息系统使用者的需求不同而发生变化。

个人用户最为关心的信息系统安全问题是怎样保证涉及个人隐私的问题。企业用户看重的是怎样保证涉及商业利益的数据的安全。这些个人数据或企业的信息在传输过程中要保证其受到保密性、完整性和可用性的保护,避免其他人,特别是竞争对手利用窃听、冒充、篡改和抵赖等手段,对其利益和隐私造成损害和侵犯,同时用户也希望其保存在某个网络信息系统中的数据,不会受其他非授权用户的访问和破坏。

从网络运行和管理者角度说,最为关心的信息系统安全问题是怎样保护和控制其他人对本地网络信息进行访问、读写等操作。例如,避免出现漏洞陷阱、病毒、非法存取、拒绝服务及网络资源被非法占用和非法控制等现象,制止和防御网络黑客的攻击。

对安全保密部门和国家行政部门来说,最为关心的信息系统安全问题是怎样对非法的、有害的或涉及国家机密的信息进行有效过滤和防堵,避免非法泄露。机密敏感的信息被泄密后将会对社会的安定产生危害,给国家造成巨大的经济损失和政治损失。

从社会教育和意识形态角度来说,最为关心的信息系统安全问题则是怎样杜绝和控制网络上的不健康内容。有害的黄色内容会对社会的稳定和人类的发展造成不良影响。

目前，信息系统工程在企业 and 政府组织中得到了广泛应用。许多组织对其信息系统的依赖性不断增长，使得信息和信息安全也越来越受到重视。由于信息化成本的限制，用户应该根据自己信息化的具体应用，制定相应的安全策略和安全管理措施。

17.2.2 信息系统安全属性

1. 保密性

保密性是应用系统的信息不被泄露给非授权的用户、实体或过程，或供其利用的特性。即防止信息泄漏给非授权个人或实体，信息只为授权用户使用的特性。保密性是在可用性基础之上，是保障应用系统信息安全的重要手段。

应用系统常用的保密技术如下。

- (1) 最小授权原则：对信息的访问权限仅授权给需要从事业务的用户使用。
- (2) 防暴露：防止有用信息以各种途径暴露或传播出去。
- (3) 信息加密：用加密算法对信息进行加密处理，非法用户无法对信息进行解密从而无法读懂有效信息。
- (4) 物理保密：利用各种物理方法，如限制、隔离、掩蔽和控制等措施，保护信息不被泄露。

2. 完整性

完整性是信息未经授权不能进行改变的特性。即应用系统的信息在存储或传输过程中保持不被偶然或蓄意地删除、修改、伪造、乱序、重放和插入等破坏和丢失的特性。完整性是一种面向信息的安全性，它要求保持信息的原样，即信息的正确生成及正确存储和传输。

完整性与保密性不同，保密性要求信息不被泄露给未授权的人，而完整性则要求信息不致受到各种原因的破坏。影响信息完整性的主要因素有设备故障、误码（传输、处理和存储过程中产生的误码，定时的稳定性和精度降低造成的误码，各种干扰源造成的误码）、人为攻击和计算机病毒等。

保障应用系统完整性的主要方法如下。

- (1) 协议：通过各种安全协议可以有效地检测出被复制的信息、被删除的字段、失效的字段和被修改的字段。
- (2) 纠错编码方法：由此完成检错和纠错功能。最简单和常用的纠错编码方法是奇偶校验法。
- (3) 密码校验和方法：它是抗篡改和传输失败的重要手段。
- (4) 数字签名：保障信息的真实性。
- (5) 公证：请求系统管理或中介机构证明信息的真实性。

3. 可用性

可用性是应用系统信息可被授权实体访问并按需求使用的特性。即信息服务在需要

时,允许授权用户或实体使用的特性,或者是网络部分受损或需要降级使用时,仍能为授权用户提供有效服务的特性。可用性是应用系统面向用户的安全性能。应用系统最基本的功能是向用户提供服务,而用户的需求是随机的、多方面的、有时还有时间要求。可用性一般用系统正常使用时间和整个工作时间之比来度量。

可用性还应该满足以下要求:身份识别与确认、访问控制(对用户的权限进行控制,只能访问相应权限的资源,防止或限制经隐蔽通道的非法访问。包括自主访问控制和强制访问控制)、业务流控制(利用均分负荷方法,防止业务流量过度集中而引起网络阻塞)、路由选择控制(选择那些稳定可靠的子网、中继线或链路等)、审计跟踪(把应用系统中发生的所有安全事件情况存储在安全审计跟踪之中,以便分析原因,分清责任,及时采取相应的措施。审计跟踪的信息主要包括事件类型、被管信息等级、事件时间、事件信息、事件回答以及事件统计等方面的信息)。

4. 不可抵赖性

不可抵赖性也称作不可否认性,在应用系统的信息交互过程中,确信参与者的真实同一性。即所有参与者都不可能否认或抵赖曾经完成的操作和承诺。利用信息源证据可以防止发信方不真实地否认已发送信息,利用递交接收证据可以防止收信方事后否认已经接收的信息。

17.2.3 信息系统安全管理体系

1. 信息系统安全管理概念

信息系统安全管理是对一个组织机构中信息系统的生存周期全过程实施符合安全等级责任要求的管理,包括如下方面。

- (1) 落实安全管理机构及安全管理人员,明确角色与职责,制定安全规划。
- (2) 开发安全策略。
- (3) 实施风险管理。
- (4) 制定业务持续性计划和灾难恢复计划。
- (5) 选择与实施安全措施。
- (6) 保证配置、变更的正确与安全。
- (7) 进行安全审计。
- (8) 保证维护支持。
- (9) 进行监控、检查,处理安全事件。
- (10) 安全意识与安全教育。
- (11) 人员安全管理等。

2. 管理体系

在组织机构中应建立安全管理机构,不同安全等级的安全管理机构可按下列顺序逐步建立自己的信息系统安全组织机构管理体系。

- (1) 配备安全管理人员:管理层中应有一人分管信息系统安全工作,并为信息系统

的安全管理配备专职或兼职的安全管理人员。

(2) 建立安全职能部门：在(1)的基础上，应建立管理信息系统安全工作的职能部门，或者明确制定一个职能部门监管信息安全工作，作为该部门的关键职责之一。

(3) 成立安全领导小组：在(2)的基础上，应在管理层成立信息安全管理委员会或信息系统安全领导小组，对覆盖全国或跨地区的组织机构，应在总部和下级单位建立各级信息系统安全领导小组，在基层至少要有一位专职的安全管理人员负责信息系统安全工作。

(4) 主要负责人出任领导：在(3)的基础上，应由组织机构的主要负责人出任信息系统安全领导小组负责人。

(5) 建立信息安全保密管理部门：在(4)的基础上，应建立信息系统安全保密监督管理的职能部门，或对原有保密部门明确信息安全保密管理责任，加强对信息系统安全管理重要过程和管理人员的保密监督管理。

GB/T 20269-2006《信息安全技术信息系统安全管理要求》提出了信息系统安全管理体系的要求，其信息安全系统管理要素如表 17-1 所示。

表 17-1 信息系统安全管理要素一览表

类	族	管 理 要 素
1 政策和制度	1.1 信息安全管理策略	1.1.1 安全管理目标与范围
		1.1.2 总体安全管理策略
		1.1.3 安全管理策略的制定
		1.1.4 安全管理策略的发布
	1.2 安全管理规章制度	1.2.1 安全管理规章制度内容
		1.2.2 安全管理规章制度的制定
2 机构和人员管理	1.3 策略与制度文档管理	1.3.1 策略与制度文档的评审和修订
		1.3.2 策略与制度文档的保管
	2.1 安全管理机构	2.1.1 建立安全管理机构
		2.1.2 信息安全领导小组
		2.1.3 信息安全职能部门
	2.2 安全机制集中管理机构	2.2.1 设置集中管理机构
		2.2.2 集中管理机构职能
	2.3 人员管理	2.3.1 安全管理人员配备
		2.3.2 关键岗位人员管理
		2.3.3 人员录用管理
		2.3.4 人员离岗
		2.3.5 人员考核与审查
		2.3.6 第三方人员管理
	2.4 教育和培训	2.4.1 信息安全教育
		2.4.2 信息安全专家

续表

类	族	管理要素
3 风险管理	3.1 风险管理要求和策略	3.1.1 风险管理要求
		3.1.2 风险管理策略
	3.2 风险分析和评估	3.2.1 资产识别和分析
		3.2.2 威胁识别和分析
		3.2.3 脆弱性识别和分析
		3.2.4 风险分析和评估要求
	3.3 风险控制	3.3.1 选择和实施风险控制措施
	3.4 基于风险的决策	3.4.1 安全确认
		3.4.2 信息系统运行的决策
	3.5 风险评估的管理	3.5.1 评估机构的选择
		3.5.2 评估机构保密要求
		3.5.3 评估信息的管理
		3.5.4 技术测试过程管理
4 环境和资源管理	4.1 环境安全管理	4.1.1 环境安全管理要求
		4.1.2 机房安全管理要求
		4.1.3 办公环境安全管理要求
	4.2 资源管理	4.2.1 资产清单管理
		4.2.2 资产的分类与标识要求
		4.2.3 介质管理
5 运行和维护管理	5.1 用户管理	4.2.4 设备管理要求
		5.1.1 用户分类管理
		5.1.2 系统用户要求
		5.1.3 普通用户要求
		5.1.4 机构外部用户要求
	5.2 运行操作管理	5.1.5 临时用户要求
		5.2.1 服务器操作管理
		5.2.2 终端计算机操作管理
		5.2.3 便携机操作管理
		5.2.4 网络及安全设备操作管理
		5.2.5 业务应用操作管理
		5.2.6 变更控制和重用管理
		5.2.7 信息交换管理
	5.3 运行维护管理	5.3.1 日常运行安全管理
		5.3.2 运行状况监控
		5.3.3 软件硬件维护管理
		5.3.4 外部服务方访问管理
	5.4 外包服务管理	5.4.1 外包服务管理

续表

类	族	管 理 要 素
5 运行和维护管理	5.4 外包服务管理	5.4.2 外包服务商
		5.4.3 外包服务的运行管理
	5.5 有关安全机制保障	5.5.1 身份鉴别机制管理要求
		5.5.2 访问控制机制管理要求
		5.5.3 系统安全管理要求
		5.5.4 网络安全管理要求
		5.5.5 应用系统安全管理要求
		5.5.6 病毒防护管理要求
		5.5.7 密码管理要求
	5.6 安全集中管理	5.6.1 安全机制集中控管
		5.6.2 安全信息集中管理
		5.6.3 安全机制整合要求
		5.6.4 安全机制整合的处理方式
6 业务持续性管理	6.1 备份与恢复	6.1.1 数据备份和恢复
		6.1.2 设备和系统的备份和冗余
	6.2 安全事件处理	6.2.1 安全事件划分
		6.2.2 安全事件报告和响应
	6.3 应急处理	6.3.1 应急处理和灾难恢复
		6.3.2 应急计划
		6.3.3 应急计划的实施保障
7 监督和检查管理	7.1 符合法律要求	7.1.1 知晓适用的法律
		7.1.2 知识产权管理
		7.1.3 保护证据记录
	7.2 依从性管理	7.2.1 检查和改进
		7.2.2 安全策略依从性检查
		7.2.3 技术依从性检查
	7.3 审计及监管控制	7.3.1 审计控制
		7.3.2 监管控制
8 生存周期管理	8.1 规划和立项管理	7.4.1 审计结果的责任认定
		7.4.2 审计及监管者责任的认定
		8.1.1 系统规划要求
	8.2 建设过程管理	8.1.2 系统需求的提出
		8.1.3 系统开发的立项
		8.2.1 建设项目准备
		8.2.2 工程项目外包要求
		8.2.3 自行开发环境控制
		8.2.4 安全产品使用要求
		8.2.5 建设项目测试验收
	8.3 系统启用和终止管理	8.3.1 新系统启用管理
		8.3.2 终止运行管理

3. 技术体系

从安全角度,组成信息系统各个部分的硬件和软件都应有相应的安全功能,确保在其所管辖范围内的信息安全和提供确定的服务。这些安全功能分别是:确保硬件系统安全的物理安全,确保数据网上传输、交换安全的网络安全,确保操作系统和数据库管理系统安全的系统安全(含系统安全运行和数据安全保护),确保应用软件安全运行的应用系统安全(含应用系统安全运行和数据安全保护)。这 4 个层面的安全,再加上为保证其安全功能达到应有的安全性而必须采取的管理措施,构成了实现信息系统安全的 5 个层面的安全。其实,在这 5 个层面中,许多安全功能和实现机制都是相同的。例如,身份鉴别、审计、访问控制、保密性保护和完整性保护等,在每一层都有体现,并有相应的安全要求。在 GB/T 20271-2006《信息安全技术 信息系统通用安全技术要求》中将信息系统安全技术体系具体描述如下。

1) 物理安全

(1) 环境安全。主要指中心机房的安全保护,包括:

- 机房场地选择;
- 机房内部安全防护;
- 机房防火;
- 机房供、配电;
- 机房空调、降温;
- 机房防水与防潮;
- 机房防静电;
- 机房接地与防雷击;
- 机房电磁防护。

(2) 设备安全。

- 设备的防盗和防毁;
- 设备的安全可用。

(3) 记录介质安全。

2) 运行安全

(1) 风险分析。

(2) 信息系统安全性检测分析。

(3) 信息系统安全监控。

(4) 安全审计。

(5) 信息系统边界安全防护。

(6) 备份与故障恢复。

(7) 恶意代码防护。

(8) 信息系统的应急处理。

(9) 可信计算和可信连接技术。

3) 数据安全

(1) 身份鉴别

(2) 用户标识与鉴别

(3) 用于主体绑定

- 隐秘;
- 设备标识和鉴别。

(4) 抗抵赖

- 抗原发抵赖;
- 抗接收抵赖。

(5) 自主访问控制

- 访问控制策略;
- 访问控制功能;
- 访问控制范围;
- 访问控制粒度。

(6) 标记

- 主体标记;
- 客体标记;
- 标记的输出;
- 标记的输入。

(7) 强制访问控制

- 访问控制策略;
- 访问控制功能;
- 访问控制范围;
- 访问控制粒度;
- 访问控制环境。

(8) 数据完整性保护

- 存储数据的完整性;
- 传输数据的完整性;
- 处理数据的完整性。

(9) 用户数据保密性保护

- 存储数据保密性保护;
- 传输数据保密性保护;
- 客体安全重用。

- (10) 数据流控制
- (11) 可信路径
- (12) 密码支持

17.3 物理安全管理

安全对每一个公司及其基础设施都是很重要的，而物理安全也不例外。黑客也不是信息及其相关系统遭到破坏的唯一途径，物理安全还面临着大量不同的威胁、弱点以及风险。物理安全管理包括安全区域的管理、设备设施的安全管理、对环境威胁的防范以及电磁辐射的管理等。

17.3.1 计算机机房与设施安全

1. 计算机机房

对计算机机房的安全保护包括机房场地选择、机房防火、机房空调、降温、机房防水与防潮、机房防静电、机房接地与防雷击、机房电磁防护等。

1) 机房场地选择

根据对机房安全保护的不同要求，机房场地选择分为如下几种。

- (1) 基本要求：按一般建筑物的要求进行机房场地选择。
- (2) 防火要求：避开易发生火灾和危险程度高的地区，如油库和其他易燃物附近的区域。
- (3) 防污染要求：避开尘埃、有毒气体、腐蚀性气体和盐雾腐蚀等环境污染的区域。
- (4) 防潮及防雷要求：避开低洼、潮湿及落雷区域。
- (5) 防震动和噪声要求：避开强震动源和强噪声源区域。
- (6) 防强电场、磁场要求：避开强电场和强磁场区域。
- (7) 防地震、水灾要求：避开有地震、水灾危害的区域。
- (8) 位置要求：避免在建筑物的高层以及用水设备的下层或隔壁。
- (9) 防公众干扰要求：避免靠近公开区域，如运输通道、停车场或餐厅等。

2) 机房空调、降温

根据对机房安全保护的不同要求，机房空调、降温分为如下几种。

- (1) 基本温度要求：应有必要的空调设备，使机房温度达到所需的温度要求。
- (2) 较完备空调系统：应有较完备的中央空调系统，保证机房温度的变化在计算机系统运行所允许的范围内。
- (3) 完备空调系统：应有完备的中央空调系统，保证机房各个区域的温度变化能满足计算机系统运行、任意活动和其他辅助设备的要求。

3) 机房防水与防潮

根据对机房安全保护的不同要求，机房防静电分为如下几种。

(1) 接地与屏蔽：采用必要的措施，使计算机系统有一套合理的防静电接地与屏蔽系统。

(2) 服装防静电：人员服装采用不易产生静电的衣料，工作鞋采用低阻值材料制作。

(3) 温、湿度防静电：控制机房温、湿度，使其保持在不易产生静电的范围内。

(4) 地板防静电：机房地板从表面到接地系统的阻值，应控制在不易产生静电的范围内。

(5) 材料防静电：机房中使用的各种家具，如工作台、柜等，应选择产生静电小的材料。

(6) 维修 MOS 电路保护：在硬件维修时，应采用金属板台面的专用维修台，以保护 MOS 电路。

(7) 静电消除要求：在机房中使用静电消除剂等，以进一步减少静电的产生。

4) 机房接地与防雷击

根据对机房安全保护的不同要求，机房接地与防雷击分为如下几种。

(1) 接地要求：采用地桩、水平栅网、金属板、建筑物基础钢筋构建接地系统等，确保接地体的良好接地。

(2) 去耦、滤波要求：设置信号地与直流电源地，并注意不造成额外耦合，保证去耦、滤波等的良好效果。

(3) 避雷要求：设置避雷地，以深埋地下，与大地良好相通的金属板作为接地点。至避雷针的引线则应采用粗大的紫铜条，或使整个建筑的钢筋自地基以下焊连成钢筋网作为“大地”与避雷针相连。

(4) 防护地与屏蔽地要求：设置安全防护地与屏蔽地，采用阻抗尽可能小的良导体的粗线，以减少各种地之间的电位差。应采用焊接方法，并经常检查接地是否良好，检测接地电阻，确保人身、设备和运行的安全。

2. 电源

根据对机房安全保护的不同要求，机房供、配电分为如下几种。

(1) 分开供电：机房供电系统应将计算机系统供电与其他供电分开，并配备应急照明装置。

(2) 紧急供电：配置抗电压不足的基本设备、改进设备或更强设备，如基本 UPS、改进的 UPS、多级 UPS 和应急电源（发电机组）等。

(3) 备用供电：建立备用的供电系统，以备常用供电系统停电时启用，完成对运行系统必要的保留。

(4) 稳压供电：采用线路稳压器，防止电压波动对计算机系统的影响。

(5) 电源保护：设置电源保护装置，如金属氧化物可变电阻、二极管、气体放电管、滤波器、电压调整变压器和浪涌滤波器等，防止/减少电源发生故障。